

Helix OTA — Continuation

Revision: 28 Last modified: 2026-07-10T09:52:00Z

1. Current state

Field	Value
HEAD	Wave-13 consolidation (cont-8, 2026-07-10) — this commit lands the multipart spill temp-file-leak fix (server/internal/api/ handlers_artifact.go RemoveAll defer) + 3 owned-submodule gitlink bumps (docs_chain 9a5bd32→394270e, ota-android- agent de5d0e7→4e9dd89, ota-rollout-engine 23da1cd→3284620) + docs/qa/wave13-20260710/ EVIDENCE.{md,html,pdf}. Wave-13 batch (§11.4.118 loop-until-dry): 5 real fixes + 5 independent NO-DEFECT passes , each fix RED → GREEN + conductor polarity §11.4.115 + independent review §11.4.142, all FF no- force §11.4.113: compression truncated-gzip- on-panic d15e7465 (4/4) · docs_chain verify nil-corrupt-state SIGSEGV 394270e (github+gitlab) · android OtaPollWorker thrown-transient-IOException → Retry 4e9dd89 (github) · ota-rollout-engine halted- rollout re-poll reason misreport 3284620 (github) · multipart spill leak (this commit); CLEAN (enumerated coverage, fuzz+race probes, no fabrication §11.4.6): ota-artifact- validator, ota-telemetry-schema, ota- protocol, server/internal/config, server/ internal/fabric. Wave-12 (cont-7 tail, landed): security KeywordFilter empty- keyword block-all a0dad7d/parent 11c6b21b · server 2 TOCTOU races 5e4674c0 · containers

Field	Value
	3 concurrency f25228f/parent 1970c851 · server signature verifier fail-closed on malformed key 2cfb6b91. Prior — 1a2109e8 cont-7 Wave-9/10/11 audit batch (2026-07-10): 6 owned-brick/main-repo defects fixed, each RED → GREEN + conductor polarity §11.4.115 + independent review §11.4.142, all FF-pushed no-force §11.4.113: W11a ota-artifact-validator 707f876/parent 1c75fd42 (ValidateHash nil-io.Reader panic → reject verdict, reachable via exported Validate(Input{})) · W11-server 7a68a8e5 (handleCreateProject now seeds creator ProjectRoleAdmin ACL — creator was 403-locked-out of own project, entire per-project RBAC was silently dead; no route-gate change, no escalation) · W11-bridge ota-update-engine-bridge 33ab77d/parent 3c6da835 (UpdateEngine.bind() boolean was swallowed → observeStatus cold Flow hung forever on bind-fail; bind() now returns Boolean + Flow close(IllegalStateException) fails fast) · W11-agent ota-android-agent de5d0e7/parent f99f35b2 (verify RejectReason hardcoded HASH_MISMATCH masked security-relevant SIGNATURE_INVALID + download.localPath!! crash → graceful Retry) · W11-docs_chain 9a5bd32/parent 1a2109e8 (SQLiteAdapter.Read unescaped TAB/NEWLINE → distinct row states hash-collide → change-detection PASS-bluff; now escapeDumpField/nullSentinel; merged 2 upstream doc commits FF §11.4.113 + pre-existing gofmt cleanup) · W10 containers ab146b4/parent 78cd98a5 (serviceregistry.Discover fast-path returned the internal *Service pointer → registry corruption + -race; now copies under RLock) · W9 ota-protocol + ota-telemetry-schema audits CLEAN (enumerated coverage §11.4.118). Android Gradle gates ran real (system gradle 8.14.3 + ANDROID_HOME, testDebugUnitTest PASS). All

Field	Value
	parent commits IN SYNC — origin/main == 1a2109e8, every parent push 4/4 FF github+gitlab+gitflic+gitverse. Prior Wave-8 cont-6 batch — server applyport subcommand-flag-parse fix + handlers_artifact serve-the-VERIFIED-signature fix + §11.4.83 evidence, plus 4 owned-brick gitlink bumps: doc_processor 9385b7a / llms_verifier 7d06b19c / ota-rollout-engine 23da1cd / security 682e0a6; pushed 4/4 FF github+gitlab+gitflic+gitverse, no force §11.4.113. Prior Wave-7 tail 392bb260 — server 7-defect audit ace4b985 [api IP-spoof audit-log security + refresh-TTL + PATCH-description; store map-aliasing + non-deterministic pagination + HW-reindex + pg ErrConflict, proven on real rootless-podman Postgres; transport §11.4.120 gate reconcile] + 86df7293 request-body wire reconcile + 461977cc rollout/artifact pointer bumps + 392bb260 4 submodule pointer bumps: security 44f4257 / telemetry 847244a NaN-threshold / http3 a56d040 close-race+Validate / ota-protocol 8412469 whitespace-idents) — verified FF-present on github+gitlab+gitverse == local HEAD (bounded ls-remote 2026-07-10T00:48Z; gitflic/upstream network-UNREACHABLE this session, buffered per §11.4.88, no force §11.4.113). Wave-8 IN FLIGHT (3 disjoint background streams, §11.4.103/§11.4.119): L=server internal/ {device,deviceemu,fabric,health,config}, M=submodules/llms_verifier, N=submodules/doc_processor — conductor verifies (§11.4.142) + polarity + commits on return. OPERATOR-BLOCKED: vision_engine J-fix 1ec0c57 (6 verified defects) committed LOCAL only — origin fetch=vasic-digital/VisionEngine/push=HelixDevelopment/VisionEngine diverged (HD carries gov-doc anchors CM-COVENANT-114-70..74 my lineage lacks); needs operator canonical-

Field	Value
	mirror decision + gov-doc UNION merge, never keep-ours/force (§11.4.101/§11.4.113). Superseded prior tip: 6ec752cb (+ containers submodule a9c660d) — pushed FF to the 3 REACHABLE mirrors (github/gitlab/gitverse+origin); gitflic/upstream are network-UNREACHABLE this session (proven via bounded <code>ls-remote >8s</code> timeout) so their pushes fail-fast + buffer to qa-results/push_failures/ (§11.4.88, retried next reachable tick, no force §11.4.113). Root-cause fix applied: <code>git config core.sshCommand "ssh -o ConnectTimeout=10 -o ServerAliveInterval=5 -o ServerAliveCountMax=2"</code> so an unreachable gitflic can no longer HANG <code>git fetch --all</code> (it wedged a <code>commit_all.sh</code> ~10 min this session; §11.4.101/§11.4.180 the wedged pre-commit process was proven-dead-on-fetch, killed + its lock reaped, no data written). Wave-7 (2026-07-10 cont-3): 280190e0 item I1 HSTS + upgrade-insecure gated on config-resolved TLS (<code>tlsEnabled()=(cert&&key) TrustTLSProxy</code>, new <code>HELIX_TRUST_TLS_PROXY</code> env default-false; NO request header consulted → unspoofable; §11.4.115 RED → GREEN, conductor <code>gofmt/vet/build/test</code> GREEN §11.4.142) · b290d945 client NON-LIST wire audit (subagent, conductor-verified §11.4.142: independent <code>tsc 0 + vitest 13-files/51-pass + 3 strongest drift claims cross-checked field-for-field</code> vs real Go structs — 15/19 interfaces drifted incl near-total fabrications <code>DeviceRegistered/DeviceStatus/DeviceHealth/ReleaseResponse/Deployment/RolloutState/RolloutDecision/Group</code>; fixed 15 + added 7 + 10 hooks + guard test; follow-up: REQUEST-body interfaces <code>RecallRequest/DeviceRegistrationRequest/CreateReleaseRequest</code> also drifted — recall would reject every request — dispatched as its own stream) · 6ec752cb dist/ SPA bundle

Field	Value
	regenerated from committed audit source (§11.4.108/§11.4.77 — vite build exit 0; an earlier untracked bundle had a non-matching JS hash, superseded; dist is nginx-standalone, NOT the go:embed manager-dist). 3 IN-FLIGHT subagents: request-body wire audit + ota-artifact-validator + ota-rollout-engine audits. Wave-6 (2026-07-10 cont-2): 95c3a533 TEL/BUG-1 telemetry real-shape mapping (dashboard hook was a bare re-export casting the raw /telemetry/overview body to a FABRICATED camelCase shape → every stat card read undefined; now a mapping adapter onto the real {event_counts,total,failure_rate,by_state}; pendingUpdates = the four NON-terminal buckets verified EXACTLY vs submodules/ota-protocol/enums.go:201-206, by_state fed by handlers_client.go:207 UpdateState=string(ev.Event)); independently re-verified §11.4.142, tsc 0 vitest 49/49, +HTML/PDF/DOCX evidence) · 1a526ab containers idle-shutdown stale-fire race (submodule, all 5 mirrors — fire() gained a lastTouch-vs-timeout guard that reschedules instead of shutting down when a Touch beat the timer; UNEXPORTED clock-injection seam makes the sub-ms race deterministic; §11.4.115 fake-clock RED → GREEN, -race×3, conductor-verified) · /healthz follow-up RESOLVED not-reproducible (§11.4.90 — zero client callers repo-wide; server correctly serves /healthz+/readyz unversioned) · client-wire list-shape reconciliation CLOSED (this commit — 6 client list interfaces declared the wrong {items,total,cursor}; fixed to {items,next_cursor} for DeviceList/ReleaseList/GroupList/TelemetryHistory/DeploymentList and {items} for RollbackList, matched to the real server structs + compile-time guard test; tsc 0, vitest 50/50). Wave-5 (2026-07-10 cont. —

Field	Value
	operator decisions executed): 992bd497 O-impl tiered security headers (global nosniff/frame-DENY/COOP/CORP/TLS-gated-HSTS wired to survive 404/401/500/429-shed + /api/v1 CSP+no-store + SPA-document CSP with style-src unsafe-inline for React19 hoisting, upgrade-insecure TLS-gated to avoid plain-HTTP white-screen; conductor-reverified 8/8 header tests PASS 0-skip incl TestSPACSP_CompatibleWithRealBundle, full internal/api -race clean 12.6s) · d97d85a2+8f68cb0b item Q closed (HELIX_MAX_INFLIGHT documented in .env.example + system.compose.yml; operator kept 0=unlimited, OOM-risk stated, limiter guards memory not CPU) · 3ada0a12 mirror-fork brief (LLMProvider IS a dep via llm_orchestrator/go.mod:18 → keep origin helix-deps.yaml). C-impl (ota-manager router) + DASH (dashboard regression) + BT (owned-Go-brick test sweep) in flight. Wave-4 (2026-07-10 — Postgres + review-remediation + gofmt sweep + operator briefs): 720ef748 READINESS Rev3 + M2 Postgres integration RAN e2e (15/15 ok + -race clean, real pgx TCP-kill/SQLSTATE 23514/uq_fabric_lease_active fault evidence, self-booting postgres:16-alpine rootless podman) · 1df9a649 memory-leak discriminator fix (whole-branch-review Important-1: per-batch-delta was blind to a steady leak → rewrote to retention-scales-with-load, self-validated classifier + §11.4.115 RED on a real 4 KB/iter injected leak leak=true, healthy leak=false) + N-sec server hardening (security suite PASS under -race+fuzz 115k execs; benchmark baseline + new token_bench_test.go) · f7846319 5-brick gofmt sweep pointer bump (challenges/containers/llms_verifier/ota-protocol/security FF-pushed; gofmt-equivalence proven; llm_orchestrator+vision_engine DEFERRED

Field	Value
	for pre-existing mirror fork) · 63095b03 Stream FS full-server-suite GREEN on HEAD + gofmt reconciliation + whole-branch review GO-WITH-FIXES · 660e8e6d operator decision briefs (security-headers/DDoS- default O/Q + ota-manager router C). Prior wave-2/3 HEAD ca3860d8 — 29 commits: Wave-2 (S/T/U/V) all landed: a8c12d9a ota- manager shadcn AA fix (S — closes A2; S caught a rounding trap in M's audit, used precise values, 38/38 verified) · 870ca9ff dashboard screen×STATE empty+error for Releases/Fleet (U — 81 → 117) · 5a3e036a llms_verifier pointer bump (T — RED tests were a foreign-TLS-on-port-8080 §11.4.3 SKIP condition, test-side fix + 11 upstream commits integrated) · ca3860d8 server §11.4.169 coverage audit (V). Through 444b68f4: 35035ba4 brand tokens · cc3f5dc8 vendoring plan · 26e98390/d7491292 device- claim+signed-pipeline · 74b94bb8 ota- manager vendor+toggle-fix · 4c6b201d dashboard vendor+dark-mode+controller- tests · 961ec31c UI audit+WCAG contrast · 6466edc2 guard-hook root-cause · 28ce6fd6 ota-manager RED-suite restore+latent-bugfix · 94fb10a2 typecheck-gate-fixed · 444b68f4 dashboard hex-completion. After: a0df513b CONTINUATION Rev15 · 7fb2a724/acf3c012 server SPA greedy-fallback → asset-aware-404 (§11.4.120-reconciled) + real-router asset- chain tests · dbc20d51 WCAG-AA token re- vendor (danger/warn/success/muted + border-strong, computed ratios + host- render re-proof) · 604c0508 server SPA §11.4.85 stress+chaos incl. traversal-no- escape census · cdce12c7 dashboard light- golden evidence re-sync (45/45) · 7c95b763 readiness ledger Rev 2 · d463ec3e ota- manager shadcn WCAG audit (M) · f553104f challenges pointer bump (K: Result.RecordAction race + chaos FAIL-bluff fixed, FF to brick remotes) · df2784ec

Field	Value
	dashboard host-render 5 → 9 screens (R) · 34f7dcf6 ota-manager 118 → 85 type errors, 33 router-independent fixed (P) · 95d8328e submodule-brick health audit (K). Prior constitution-adoption HEAD 634fcb50. OPENDESIGN ADOPTION — COMPLETE (2026-07-09) — autonomous loop (§11.4.126). Both web frontends fully ADOPTED: design-systems/helix-ota/ brand tokens authored → vendored byte-identical into clients/ota-manager + dashboard → ota-manager theme-toggle DOM-class bug FIXED → dashboard real light/dark theme added + controller tested → all screen hex repointed to tokens → proven light+dark by §11.4.170 host-render (self-validated oracles) on both. UI-surface audit: ota-manager+dashboard ADOPTED, server N/A (serves SPA), Android agents N/A/headless. Remaining = polish/hardening follow-ups (see §5), all non-blocking. Prior: TEST-COVERAGE PROGRAM (2026-06-23) Phase 0 DONE + Phase 1 mostly done. Cuttlefish Tier-2 A/B VERIFIED (F112/F55). Fully validated Helix OTA control plane driving real Android A/B updates end-to-end (protocol round-trip → payload apply → slot switch → rollback) on emulated + physical targets — MET for the emulated Cuttlefish A/B path (F112/F55 VERIFIED); RK3588 stays control-plane-only by operator decision (§11.4.133)
Phase	
Terminal goal	

Latest session (2026-07-10, cont-8) — Wave-12 + Wave-13 landed; §11.4.118 loop measurably drying (5 fixes + 5 clean)

Standing directive (§11.4.126): endless autonomous loop, 3-4 parallel subagents, rock-solid physical evidence, no bluff. This continuation ran deep 2nd/3rd-pass adversarial audits (§11.4.118 discovery-pressure) across owned bricks + server packages, each closure conductor-

independently re-verified (§11.4.142 + §11.4.115 polarity: compile-safe mutation → guard FAILs → sha256 byte-identical restore → GREEN). All submodule fixes FF-pushed to their mirrors (no force §11.4.113); the Wave-13 consolidation parent commit lands the gitlink bumps + evidence.

- **Wave-13 — 5 real fixes, each RED → GREEN + conductor polarity, all published:** compression truncated-gzip-on-panic d15e7465 (4/4 github/gitlab/gitflic/gitverse) · docs_chain verify nil-corrupt-state SIGSEGV 394270e (github+gitlab) · android OtaPollWorker thrown-transient-IOException degrades to Retry not Result.failure() 4e9dd89 (github) · ota-rollout-engine halted-rollout re-poll misreports halt cause 3284620 (github) · server multipart spill temp-file leak RemoveAll (this consolidation commit). Evidence: docs/qa/wave13-20260710/EVIDENCE.{md,html,pdf} + scratchpad/polarity_*.py harnesses.
- **Wave-13 — 5 independent NO-DEFECT passes (§11.4.118, enumerated coverage, no fabrication §11.4.6):** ota-artifact-validator · ota-telemetry-schema (fuzz 257k execs) · ota-protocol (fuzz+chaos) · server/internal/config (artifact-pubkey trust boundary fail-closed by FACT — len==ed25519.PublicKeySize gate, never from request) · server/internal/fabric (80-goroutine -race probe; CompleteRun PASS-requires-evidence TOCTOU proven NOT violable — evidence is append-only, no removal path).
- **Wave-12 (cont-7 tail, landed):** security KeywordFilter stray-empty-keyword block-all a0dad7d/parent 11c6b21b · server 2 business-invariant TOCTOU races (handleCreateDeployment+handleCreateRelease — check-then-act across two individually-locked store calls, invisible to -race, proven by N=10 barrier-released outcome tests) 5e4674c0 (subject garbled to “-F”; commit_all.sh takes -m/COMMIT_MESSAGE not git’s -F — recovered in docs/qa/wave12-20260710/EVIDENCE.md) · containers 3 concurrency (overlay unguarded map / scheduler placements race / bus Close-under-lock deadlock) f25228f/parent 1970c851 · server SignatureVerifier fail-closed on malformed ed25519 key (was panic) 2cfb6b91.
- **Convergence status:** the §11.4.118 loop is drying but NOT declared dry — server/internal/deviceemu (~2537 LOC emulation harness) + several containers/docs_chain/ota-update-engine-bridge packages remain un-deep-audited; a further targeted round (Wave-14) is warranted before claiming the known-issue set complete. **Release tag remains gated on §11.4.185 QA-team manual confirmation** + the 3 OPERATOR-BLOCKED mirror-fork publishes (vision_engine 1ec0c57 / llm_orchestrator O-fixes / llm_provider nil-ctx crash-fix —

one fleet-wide operator canonical-mirror decision, never keep-ours/force §11.4.113).

Latest session (2026-07-10, cont-6) — Wave-8 3-stream results verified+landed; parent batch published 4/4; Wave-9 both CLEAN

Standing directive (§11.4.126): endless autonomous loop, 3-4 parallel subagents, rock-solid physical evidence, no bluff. This continuation processed all 3 Wave-8 background streams (security / server-sig / server-discovery), conductor-independently re-verified each (§11.4.142 + §11.4.115 polarity, compile-safe mutation → guard FAILs → byte-identical restore), landed the batch, and re-fanned Wave-9. Parent HEAD 601f0e51 → 7b86a6da, pushed 4/4 FF (github/gitlab/gitflic/gitverse all OK), no force (§11.4.113).

- **security 682e0a6 COMMITTED + FF-PUSHED (github+gitlab):** 2 verified defects — (1) `Enforcer.Evaluate` bypassed the injected `PolicyEvaluator`: the single-policy path called `package-level evaluatePolicy` directly, ignoring `SetPolicyEvaluator`, so a stricter/custom decision fn was silently skipped (a policy-enforcement bypass); fix routes through `e.policyEvaluator` like `EvaluateAll` — default path unchanged since `NewEnforcer` inits it to `evaluatePolicy` (no nil-panic, no behavior change unless injected). (2) `Redactor.Redact` corrupted output on OVERLAPPING PII detections: the descending-start splice applied each match's ORIGINAL offsets to an already-mutated string → garbled output that could re-splice ORIGINAL PII bytes back into the “redacted” result, map-order-dependent; fix `resolveOverlaps` coalesces into deterministic non-overlapping union spans (sorted `Start↑, End↓, Type↑`), removed superseded `sortMatchesDescending` (§11.4.124, zero remaining callers). Conductor polarity both (mutation reproduced the exact corruption card: ***-***-5112****-0366 byte-for-byte), byte-identical restore. Its parent gitlink bumped in 7b86a6da.
- **server 2 fixes LANDED in 7b86a6da:** (a) `cmd/applyport/main.go` — flags AFTER the subcommand were silently dropped (`flag.Parse()` parses `os.Args[1:]` and stops at the subcommand positional → `applyport run -server ... -pubkey ...` reverts every flag to env/default; a dropped `-pubkey` silently DISABLES the signature verification the operator explicitly asked for); fix extracts the subcommand then `flag.CommandLine.Parse(os.Args[2:])`. Guard `TestRun_SubcommandFlagsAreParsed`. (b) `internal/api/handlers_artifact.go` — the server STORED/SERVED the unverified `meta.Signature` while cryptographically verifying a possibly-

different `resolveSignature()` result → an upload with a valid signature form-part + a divergent `metadata.signature` is accepted 201/Verified:true, but the device is served the divergent sig and fails to install while the server reported valid/published (§11.4 validation-passes-but-broken); fix stores `base64(the VERIFIED sig)` as the single source of truth — canonical meta-only publishes round-trip identically (no false-reject, §11.4.1). Guard `TestArtifactUploadServesVerifiedSignature` (drives the real / client/update device path; built-in RED_MODE polarity switch, cross-checked FAIL on the fixed tree). Both conductor polarity-proven (§11.4.115). §11.4.83 transcript+html/pdf/docx siblings committed under `server/docs/qa/20260710-server-signature-consistency/`.

- **4 owned-submodule gitlink bumps LANDED in 7b86a6da** (verified exact): `doc_processor 96fc7e4→9385b7a`, `llms_verifier 02ac454→7d06b19c`, `ota-rollout-engine 54a1172→23da1cd`, `security 44f4257→682e0a6`. The 3 forks (`vision_engine 1ec0c57` / `llm_orchestrator 0` / `llm_provider`) intentionally NOT bumped — cross-org mirror divergence, fixes preserved to scratchpad, ONE fleet-wide operator canonical-mirror decision still pending (§11.4.101).

- **Wave-9 dispatched — BOTH CLEAN (no new defects, full §11.4.118 enumeration, no fabrication §11.4.6):** `ota-protocol` (trust-path S6 `ValidateMetadata`) — CLEAN; the signature-presence-not-crypto-validity boundary is the DELIBERATE pure-contract/stdlib-only scope (real verify is server-side), matching the sig-mismatch finding — not a new defect; `build/vet/gofmt/-race` green + 2 fuzzers (34k / 753k execs, 0 crashes). `ota-telemetry-schema` — CLEAN; the NaN-threshold hole this class is prone to was ALREADY fixed Wave-7 (`health.go:53,59 math.IsNaN`, telemetry pointer `847244a`), re-verified correct + no sibling holes; `build/vet/gofmt/-race` green. Neither changed a file → no commit needed. Two more owned bricks confirmed hardened.

- **Working-tree note (§12.10 honesty):** the parent `docs/** HTML/PDF/DOCX` exports show as modified — a stray `full export_docs.sh` run (triggered by the `server/docs .md` sibling-gap on the first commit-1 attempt, since resolved by pre-generating the transcript's flat siblings) regenerated all 96; they are REGENERABLE, were NOT staged by the explicit `--paths` commits, and were NOT committed. Foreign `docs/qa/20260709-* dashboard` churn + dirty foreign submodules (`helixqa/challenges/http3`) are another actor's WIP — left untouched (§11.4.174). Release tag still gated on §11.4.185 QA-team manual confirmation.

Latest session (2026-07-10, cont-5) — Wave-8 verify/commit backlog drained + 3rd mirror-fork operator-block + fresh server-audit fan-out

Operator directive (re-sent, standing §11.4.126): endless autonomous loop, 3-4 parallel subagents, rock-solid physical evidence, no bluff. This continuation processed the Wave-8 audit results and re-fanned. Every stream conductor-independently re-verified before commit (§11.4.142 + §11.4.115 polarity); all pushes FF, no force (§11.4.113). Parent HEAD still 601f0e51; the two clean submodule commits below are pushed to their own mirrors — **parent-pointer bumps for them are BATCHED** (one commit_all.sh coverage-gate run) pending the in-flight server streams, together with this Rev25.

- **M — submodules/llms_verifier 7d06b19c COMMITTED + FF-PUSHED (github+gitlab == 7d06b19c):** 5 verified defects — D1a VerifyModelCodeVisibility 0.7 score-floor inflated a code-DENIAL into a pass (gated on CodeVisibility), D1b timeout-penalty 0.3 floor applied to a blind model (extracted pure applyVerificationTimeoutPenalty, floor only when codeVisible), D2 calculateMatchScore strings.Contains(name, "")-always-true made a blank query match every catalogue model (TrimSpace==" → 0.0 + FindModel fail-fast), D3 advanced_monitor.go HealthCheck read len(am.metrics) without am.mu (real map read/write race, guard = existing TestAdvancedMonitor_ConcurrentAccess under -race), D4 health.go Stop() didn't wait for the Start ticker goroutine → leaked goroutine's tr() i18n read raced the next test's withFakeMonitorTranslator write (added wg sync.WaitGroup; also §11.4.14 cleanup). D5 test-double mutex accepted. Conductor polarity (§11.4.115) all 5 + byte-identical restore; verification+monitoring+enhanced/context -race green.
- **ota-rollout-engine 23da1cd COMMITTED + FF-PUSHED (origin == 23da1cd):** NaN thresholds/rates silently bypass the rollout HALT safety invariant. $x < lo || x > hi$ accepts NaN (every NaN compare false), then $errorRate \geq errorThreshold$ with a NaN operand is also false → the documented "halt wins / when in doubt stop" gate is disabled. Two loci: types.go validatePhases (config-time), verdict.go HealthVerdict.validate (runtime: error_rate=0/0=NaN when no terminal device). math.IsNaN guards. Regression nan_validation_test.go drives the PUBLIC API (Create/Evaluate) — no unexported-field shortcut. Conductor polarity (§11.4.115): neutralize both guards compile-safe (&& false, math still referenced → real test FAIL not an §11.4.1 build break) → both tests FAIL with Decision Status:active (halt bypassed); byte-identical restore.

- **ota-artifact-validator — CLEAN in-library (100% stmt coverage, -race green)** but SURFACED a real SERVER-side gap (dispatched as a stream below): `Input.Signature` (verified []byte) vs `Meta.Signature` (non-empty string) are never cross-checked; server `handlers_artifact.go:274 resolveSignature` can prefer an uploaded signature form-part over `meta.Signature` → the served signature could differ from the verified one → a device gets a non-matching sig + fails to install while the server reports “valid/published” (§11.4 validation-passes-but-broken). Correctly NOT patched in the decoupled encoding-agnostic library (§11.4.28) — fix belongs at the server layer.
- **llm_provider — OPERATOR-BLOCKED (3rd mirror fork), fix preserved:** 1 verified defect — `HealthMonitor.ForceCheck()` panics cannot create context from nil parent when called before `Start()` through the EXPORTED API (`New` → `RegisterProvider` → `ForceCheck`; `hm.ctx` nil until `Start`). Textbook §11.4 test-bluff: pre-existing tests set the UNEXPORTED `hm.ctx` directly. Fixed both loci (root + pkg/health) with a nil-ctx → Background fallback + de-bluffed the 2 masking tests (§11.4.120) + 2 public-API RED guards. Honest §11.4.124: 2 unwired zero-caller smells left untouched. **Publish blocked** — 3-way cross-org fork: local master 79bab387 (+125 over merge-base efa22b6), HelixDevelopment (github+upstream) 4749d46 (+120), vasic-digital (gitlab+origin) 8905a76 (+2); none an ancestor of another. Fix preserved to scratchpad `llm_provider_preserve/`; NOT polarity-checked (deferred until the operator picks the canonical tip). Memory `llm-provider-mirror-fork.md`.
- **O — submodules/llm_orchestrator OPERATOR-BLOCKED, fixes preserved:** 3 audit-found defects (simple_pool.go capacity over-provision race via building counter; parser.go nondeterministic action order; multi_pool.go cross-pool release contamination via owners map) + 3 RED tests, NOT committed. Base HEAD a484f7dd is detached AND has git conflict markers COMMITTED into 7 governance blobs (CLAUDE/AGENTS/CONSTITUTION/QWEN=6 each, README=15, docs=3, .gitignore=12); origin fetch=vasic-digital/push=HelixDevelopment diverged (HD bde36431 vs VD 9c9db1dc). Fixes preserved to scratchpad `o_llm_orchestrator_preserve/` (o_fixes.diff 244 lines + 3 tests, code files marker-free). Memory `llm-orchestrator-mirror-fork.md`.
- **THREE owned submodules now blocked on the SAME root cause** (cross-org diverged mirrors): `vision_engine` (J, 1ec0c57), `llm_orchestrator` (O), `llm_provider`. Operator needs ONE fleet-wide canonical-mirror decision (which org is canonical) + per-repo

careful UNION reconciliation (never keep-ours/force §11.4.113).
Their parent-pointer bumps stay deferred.

- **3 streams IN FLIGHT (§11.4.103/§11.4.119, background, conductor reviews+commits on return):** (sec) submodules / security adversarial audit; (sig) server signature-mismatch VERIFY-then-fix (prove reachability as FACT first, fix at server layer only, §11.4.6); (disc) discovery audit of the un-audited server/internal packages (skip api/store/device/deviceemu/fabric/health/config already covered). Each: own scope, NO git (§11.4.20), RED → GREEN or honest clean (§11.4.6), captured evidence.

Latest session (2026-07-10, cont-4) — Wave-7 server+brick defect batch LANDED + Wave-8 3-stream fan-out + vision_engine operator-block

Operator directive (re-sent, standing §11.4.126): continue the endless autonomous loop with 3-4 parallel subagents on real evidence, no bluff. This continuation drained the Wave-7 review+commit backlog (server + owned Go bricks), landed 13 verified defects across 8 components, and re-fanned Wave-8. Every stream conductor-independently re-verified before commit (§11.4.142); all pushes FF, no force (§11.4.113). **Reconciliation note:** on resume, CONTINUATION was stale at Rev23/HEAD 6ec752cb while the real linear coherent tip was 392bb260 (proven: 6ec752cb IS ancestor of 392bb260; 3 reachable mirrors == local HEAD) — no divergence, no loss, just a \$12.10 lag now closed by this Rev24.

- **Wave-7 server audit LANDED** (ace4b985, Stream H+I, 4/4 reachable mirrors): 7 verified defects. **api (H):** X-Forwarded-For audit-log IP-spoof (SetTrustedProxies(nil) — audit IP now unspoofable, §11.4.115 polarity: mutation → TestAuditLogIPAddressNotSpoofableViaXForwardedFor FAILS, restored GREEN) + refresh-token TTL (defaultRefreshTokenTTL=30d) + PATCH-description (UpdateProjectRequest/GroupUpdate.Description string → *string omitempty so a real empty-string clear is distinguishable from absent). **store (I):** cloneStrMap on all Device.Metadata/AuditEntry.Details/ RollbackRecord.Details read+write paths (map-aliasing leak) + devOrder insertion-order slice (non-deterministic map-iteration pagination) + UpdateDevice HW-reindex + ErrConflict on collision + postgres UpdateDevice isUniqueViolation→ErrConflict — **proven on a real rootless-podman postgres:16 via go test -tags integration. transport (§11.4.120):** reconciled TestNewWrapsHTTP3ConstructionError to assert the two stable cert-

source terms independently (robust to http3 a56d040's reword listing GetConfigForClient), not the whole reworded sentence.

- **4 submodule pointer bumps LANDED** (392bb260, 4/4 reachable): security 44f4257 (CRITICAL AEAD directional-nonce reuse + NAT64 SSRF + privesc), telemetry 847244a (NaN health-threshold accepted → `math.IsNaN` guard; `Go NaN<0 && NaN>1` both false silently passed), http3 a56d040 (concurrent close false-done Nth-caller-nil via `sync.Once+shared closeDone/closeErr + Validate GetConfigForClient-only TLS`), ota-protocol 8412469 (whitespace-only required identifiers passed → `isBlank` guard after `=="`", widened to full ASCII `\n\r\v\f`). Each already on its origin/main FF-only.
- **vision_engine (Stream J) — 6 verified defects COMMITTED**
LOCAL 1ec0c57, PUBLISH OPERATOR-BLOCKED: `llmvision` `MaxImageSize` order-dependence (`seen bool`), `config NaN SSIMThreshold` (`math.IsNaN`), graph mermaid-ID collision (`mermaidIDMapper`), remote `VisionSlot` data-race (`atomic.Int64`, `separate-from-mu`), distributed `ProbeHosts` cancel (`break-only-exits-select` → `if ctx.Err()!=nil`), reconciled the brick's own broken anti-bluff Challenge to the current honest `StubAnalyzer` contract. Publish blocked: `origin fetch=vasic-digital/VisionEngine/ push=HelixDevelopment/VisionEngine` diverged (HD has gov-doc commits 3aa6d0d+1c7e3fd adding CM-COVENANT-114-70..74; keep-ours would DROP those 5 anchors). Per §11.4.101 (irreversible+high-blast+undeterminable) surfaced for operator decision (canonical mirror + gov-doc UNION merge, never force §11.4.113). Recorded to session memory `vision-engine-mirror-divergence.md`. Pointer bump deferred.
- **Wave-8 dispatched (3 disjoint background streams, §11.4.103/ §11.4.119, IN FLIGHT):** `L=server internal/ {device,deviceemu,fabric,health,config}` (aa99fe39c), `M=submodules/llms_verifier` (a66f1f08), `N=submodules/doc_processor` (a650db39). Each: own scope, NO git (subagents never run git §11.4.20/§11.4.70), systematic-debugging, RED → GREEN or honest clean-audit (never fabricated §11.4.6), captured evidence. Conductor reviews + polarity + commits on return — L via `commit_all.sh --paths` once server tree quiescent, M/N into their own `.git` FF-only + deferred pointer bumps.

Operator directive (re-sent, standing §11.4.126): continue the endless autonomous loop with 3-4 parallel subagents on real evidence, no bluff. This continuation drained the Wave-7 review+commit backlog

and re-fanned 3 fresh disjoint streams. Every stream conductor-independently re-verified before commit (§11.4.142); all pushes FF, no force (§11.4.113).

- **Containers lifecycle 3-bug fix LANDED** (a9c660d, submodule all 5 mirrors — verified live via `ls-remote`, the sibling-primitive audit prompted by the `idle.go` race): (a) `LazyBooter.EnsureStarted` panicking `startFn` left state stuck at starting AND every LATER caller silently got `nil` (fabricated success) — fixed with a recover-defer converting the panic to a retrievable error + settling the flag; (b) `DefaultManager DATA RACE` (caught by `-race`) — `entry.idleCtrl` written under `m.mu` but read without it in `Stop/Acquire/release-closure/Start`, fixed by capturing under lock at every read; (c) TOCTOU DOUBLE-BOOT — `check + state='starting'` were two separate lock holds → two concurrent `Start()` both booted (double compose-up + orphan timer), fixed by one atomic lock hold released BEFORE the blocking boot (no deadlock; proven 10 callers → Up 1×). `semaphore.go` doc-only (investigated an over-release hazard, PROVED a CAS guard changed nothing, reverted, documented the caller-discipline boundary — no fabricated fix §11.4.6). 5 new deterministic tests, `-race -count=3` 198/198 PASS. Conductor-verified §11.4.142.
- **item I1 — HSTS + upgrade-insecure gated on config-resolved TLS** (280190e0): behind a TLS-terminating proxy the app gets plain HTTP so HSTS was silently never set. Fix
`tlsEnabled()=(TLSCertFile&&TLSKeyFile)||cfg.TrustTLSProxy, new Config.TrustTLSProxy from env HELIX_TRUST_TLS_PROXY` (default FALSE = behaviour byte-identical). Pure operator boolean; NO request header (X-Forwarded-Proto) consulted → cannot be client-spoofed into forcing HSTS over plaintext. §11.4.115 RED → GREEN. Conductor-verified §11.4.142: gofmt clean, vet 0, build 0, api+config test packages PASS. docs/qa/20260710-i1-hsts-trust-proxy/.
- **client NON-LIST wire audit CLOSED** (b290d945, subagent, conductor-verified §11.4.142): every non-list RESPONSE interface in `api-client.ts` audited vs the real Go structs. Far worse than the one hypothesized `TelemetryHistory.device_id` omission — **15 of 19 interfaces drifted**, several near-total fabrications (`DeviceRegistered`, `DeviceStatus`, `DeviceHealth`, `ReleaseResponse`, `Deployment`, `RolloutState`, `RolloutDecision`, `Group` shared almost NO fields with the real struct → undefined field reads across the whole UI). Fixed 15 + added 7 (`DeviceListItem/DeploymentProgress/RolloutPhaseSpec/GroupMemberView/AuditActor/RollbackView/TelemetryEventView`) + 10 hooks + device-detail-page + 2 fixtures + new guard test wire-shape-nonlist.test.ts. Artifact/

ArtifactUploadMetadata/DeltaView/TelemetryOverview verified already-correct. **Conductor independently re-ran** tsc 0 + vitest 13-files/51-pass AND cross-checked DeviceRegistered/Deployment/Group field-for-field vs the real Go structs (exact, omitempty → optional correct). §11.4.115 RED (device_id dropped → real TS2353/TS2578). docs/qa/20260710-client-nonlist-wire-audit/.

- **dist/ SPA bundle regenerated** (6ec752cb, §11.4.108/§11.4.77): rebuilt from the committed audit source (pnpm build exit 0, 1909 modules). An earlier in-session UNTRACKED bundle had a JS hash NOT matching the committed source (would have embedded a stale bundle) — the rebuild's index-DGz1W2ft.js supersedes it (CSS index-BD87r2I_.css reproduced identically). dist is the nginx-standalone variant, NOT the go:embed manager-dist. Slated for gitignore under item K.
- **gitflic-hang ROOT CAUSE fixed** (§11.4.101/§11.4.102/§11.4.180): a pre-summary commit_all.sh wedged ~10 min in git fetch --all --prune because gitflic.ru/upstream are network-unreachable this session (proven: bounded ls-remote >8s timeout; github/gitlab/gitverse/origin reachable) and git had no SSH ConnectTimeout → indefinite hang. The wedged process was pre-commit (nothing staged), proven-dead-on-fetch, so it was killed + its now-provably-stale lock reaped (no data written — §9.2 satisfied, NOT a live-writer). Applied git config core.sshCommand with ConnectTimeout=10 so any unreachable mirror now fails-fast; commit_all.sh:661 already || true-tolerates a fetch non-zero, so commits proceed and gitflic buffers to qa-results/push_failures/.
- **3 fresh disjoint streams dispatched** (§11.4.103/§11.4.119, background): (A) client REQUEST-body wire audit + fix (real bug: RecallRequest sends {reason, force} but server needs {to_release_id, reason?} → recall rejects every request); (B) ota-artifact-validator security-sensitive validation correctness + coverage audit; (C) ota-rollout-engine state-machine + concurrency + coverage audit. Each: own scope, NO git, systematic-debugging, RED → GREEN or honest clean-audit (never a fabricated fix §11.4.6), captured evidence. Conductor reviews + commits on return.

Latest session (2026-07-10, cont-2) — BUG-1 telemetry fix + containers idle-race fix + follow-up triage

Operator directive (re-sent, standing §11.4.126): continue the endless autonomous loop with 3-4 parallel subagents on real evidence, no bluff. This continuation drained the post-fan-out follow-up queue. Every stream conductor-independently re-verified before commit (§11.4.142); all pushes FF, no force (§11.4.113).

- **TEL / BUG-1 telemetry model-drift CLOSED** (95c3a533, §11.4.6/ §11.4.115): the C-impl-disclosed pre-existing bug.
useTelemetryOverview.ts was a bare re-export casting the raw GET / telemetry/overview body to a FABRICATED camelCase shape the server never sends → every dashboard stat card silently read undefined. Now a mapping adapter onto the REAL wire shape {event_counts,total,failure_rate,by_state}; every stat real-derived. **Independently verified (§11.4.142, not the subagent self-report):** traced by_state keys to the authoritative submodules/ota-protocol/enums.go:201-206 TelemetryEvent enum (download_started/installing/installed/verifying/success/failure, fed via handlers_client.go:207 UpdateState=string(ev.Event)) — pendingUpdates = the four NON-terminal buckets is EXACT and complete; activeDeployments = / deployments.items.length confirmed (handleListDeployments calls ListActiveDeployments unconditionally). tsc 0, vitest 49/49 (new non-tautological 5-case test: totalDevices=42 vs pendingUpdates=8 proves selective sum). +HTML/PDF/DOCX evidence siblings. docs/qa/20260710-bug1-telemetry-fix/.
- **Containers idle-shutdown stale-fire race CLOSED** (1a526ab, submodule, all 5 mirrors — the BT-stream ROOT CAUSE, previously reverted-unproven): IdleShutdown.fire() shut the service down whenever stopped==false, ignoring a Touch() that reset the timer AFTER it was scheduled (Go AfterFunc+Reset race: fire() goroutine blocks on the lock while a concurrent Touch resets). Fix: fire() computes sinceLastTouch and, if < timeout, reschedules for the remaining duration instead of firing. Made deterministic via an UNEXPORTED clock-injection seam (clock.go; NewIdleShutdown public signature byte-identical). §11.4.115 fake-clock RED (guard stripped → onIdle wrongly fires) → GREEN. Conductor-re-verified: -race×3, vet+gofmt clean, full lifecycle regression ok. submodules/containers/qa-results/idle_race_fix/ (gitignored local proof; the regression test is the durable guard).
- **/healthz follow-up RESOLVED not-reproducible** (§11.4.90): the “dashboard calls /api/v1/healthz → silent 404” finding does NOT

reproduce — repo-wide grep found ZERO client callers of healthz/readyz and no versioned-health reference anywhere; the server correctly registers /healthz+/readyz unversioned (top-level, before the v1 group). No bug.

- **client-wire list-shape reconciliation CLOSED** (subagent, conductor-verified §11.4.142): 6 client list interfaces declared the wrong {items,total,cursor} (total/cursor always undefined at runtime). Fixed per-interface against the REAL server structs: DeviceList/ReleaseList/GroupList/TelemetryHistory/DeploymentList → {items, next_cursor: string|null}; RollbackList → {items} only. AuditLogList was already correct. **Subagent corrected the conductor's briefing** (§11.4.6): I mis-read DeploymentList as items-only (I checked handleListDeployments construction but not the struct) — wire.go:187-190 gives it NextCursor *string json:"next_cursor" with NO omitempty, so it emits {items, next_cursor: null}; verified directly. New compile-time guard test wire-shape-pagination.test.ts (real-shaped fixtures + @ts-expect-error on the fabricated fields; §11.4.115 RED = 6 TS2353/TS2741 on the old shape). No caller code needed fixing (request-side *Filter.cursor is a separate correct type). tsc 0, vitest 50/50. docs/qa/20260710-client-wire-shape-reconciliation/. Deferred note: TelemetryHistory also carries a server device_id field the client never declares (no caller reads it) — tracked-if-needed.
- **item E wrapper fix confirmed effective:** the commit_all.sh --paths git reset -q index-isolation (landed d3842845) worked as designed this session — the TEL --paths commit isolated exactly its listed paths despite a large shared-checkout dirty state (dist/ rebuild leftovers, other streams' docs/qa/20260709-* regenerations, foreign helixqa/challenges pointers) with ZERO leak.
- **export_docs --paths sibling gotcha (recorded):** commit_all.sh refuses a docs/qa/*.md commit lacking FLAT .html/.pdf siblings, but its auto-repair runs export_docs.sh over the whole default scope (96 files, slow, and it writes to _exports/ not flat) and never covers a brand-new evidence dir → persistent REFUSE. Resolution for new evidence dirs: run bash scripts/export_docs.sh <the-new-dir>/ then copy _exports/*. {html,pdf,docx} FLAT beside the .md before committing.

Operator directive (re-sent): continue the endless autonomous loop with 3-4 parallel subagents on real evidence, no bluff. Ran multiple parallel-subagent waves; 5 parent commits (720ef748 → 660e8e6d) + 5

submodule gofmt commits, all pushed 4/4 FF (no force §11.4.113).
Every subagent stream conductor-re-verified before commit
(§11.4.142).

- **M2 — Postgres production path RAN e2e** (720ef748): the pgx/PostgreSQL persistence path (architecture.md §4) now runs end-to-end via rootless podman self-booting postgres:16-alpine from submodules/containers; 15/15 integration packages ok + -race clean; real-DB fault evidence (pgx TCP-kill EOF, SQLSTATE 23514 CHECK, uq_fabric_lease_active lease conflict); teardown clean. Closes the Stream V audit gap (suite previously only type-checked). docs/qa/20260709-server-postgres-integration/EVIDENCE.md.
- **Whole-branch review (docs/research/session_wholebranch_review_20260710/REVIEW.md) — GO-WITH-FIXES** (0 Critical, 2 Important, 2 Minor). Verified clean: challenges RecordAction mutex (pointer-only Result, no copy hazard), FuzzTokenSignerVerify (faithful), artifact trust boundary (resolvePublicKey config-only). Important-1 FIXED ↗.
- **Memory-leak discriminator fix** (1df9a649, §11.4.4/§11.4.123): review found TestMemory_SustainedAPILoadNoGrowth's per-equal-batch-delta threshold could not detect a STEADY leak (reference contaminated by the leak) + the evidence OVERCLAIMED. Rewrote to a **retention-scales-with-load** discriminator (1× vs ~8× cumulative requests), extracted a pure classifyHeapGrowth, self-validated it (§11.4.107(10)), and PROVED detection on a real 4 KB/iter injected leak (§11.4.115 RED: retainedSmall≈8 MB retainedLarge≈65 MB → leak=true; healthy real router leak=false). docs/qa/20260710-memory-leak-discriminator-fix/EVIDENCE.md.
- **N-sec server hardening** (1df9a649, test-only): security suite re-run PASS under -race + fuzz (115k execs, 0 crashes; item P cleared); benchmark baseline + new internal/api/token_bench_test.go (Mint 803ns / Verify 1682ns / VerifyReject 481ns; item N). docs/qa/20260710-server-security-and-benchmark-baseline/.
- **Stream FS — full server suite GREEN** (63095b03): independent re-run on HEAD — build/vet/test ./... clean, 0 data races, memory + benchmark + determinism confirmed, no regression from the session's server changes. docs/qa/20260710-server-fullsuite-regression/.
- **gofmt canonicalization sweep** (f7846319 + 5 brick commits): 291 files across 7 bricks, gofmt-equivalence PROVEN (gofmt(committed)==current byte-for-byte — the correct oracle; git diff -w is wrong for gofmt). **5 LANDED** (challenges 32f6ef0, containers 367d39d, llms_verifier 02ac454d, ota-protocol 8afc07, security 96adc8b — all FF-pushed to mirrors). **2 DEFERRED** for pre-

existing mirror fork (operator decision): llm_orchestrator (github tip already gofmt-clean, origin forked +1), vision_engine (mirrors forked). docs/research/submodule_gofmt_vet_sweep_20260710/FINDINGS.md Rev 2.

- **Operator decision briefs** (660e8e6d, proposal-only/un-wired, §11.4.101/§11.4.122): (O) NO security headers set today + HELIX_MAX_INFLIGHT=0=UNLIMITED (OOM risk) → tiered-headers + 256-default proposal; (C) the 85 ota-manager tsc errors are a MIX (router migration alone fixes ~1/4); unrouted pages are INTENDED features (git a0552d8e + design spec §4) → WIRE not delete. Both need operator decisions. docs/research/operator_brief_{security_headers_ddos,ota_manager_router}_20260710/.

Latest session (2026-07-10, continued) — operator decisions executed + 4-stream fan-out

Operator answered the 3 gated briefs (C=wire all v1 routes per design spec §4; O=all tiers incl SPA-document CSP; Q=keep 0 unlimited). Executed: - **O-impl security headers LANDED** (992bd497) — three tiers wired into the real router chain, conductor-independently re-verified (§11.4.142/§11.4.6, NOT trusting the subagent): go build/go vet/gofmt -l clean, 8/8 header tests PASS with **0 skips** incl TestSPACSP_CompatibleWithRealBundle (proves the SPA-document CSP does not white-screen the real Vite/React bundle — style-src widened to 'unsafe-inline' for React19 style hoisting, upgrade-insecure TLS-gated), full internal/api suite -race clean 12.6s no regression. Purely additive; HELIX_MAX_INFLIGHT untouched. docs/qa/20260710-server-security-headers/. - **Item Q CLOSED** (8f68cb0b .env.example + d97d85a2 system.compose.yml) — HELIX_MAX_INFLIGHT documented both places; operator kept default 0=UNLIMITED, OOM risk + memory-not-CPU nature stated, #HELIX_MAX_INFLIGHT: 256 hardening knob shown. YAML re-validated. - **Mirror-fork fact resolved** (3ada0a12) — submodules/llm_orchestrator/go.mod:18 replace digital.vasic.llmprovider => ../LLMProvider proves LLMProvider IS a dep, so origin's helix-deps.yaml is factually correct; convergence deferred to an operator-batchable window (BT stream is reading those bricks now → §11.4.119 avoids write-contention). - **Parallel streams — ALL 4 DONE** (§11.4.103, disjoint scope, each conductor-independently verified before commit §11.4.142): **DASH** (52bdb1f8 — dashboard GREEN: tsc 0, vitest 107/107, host-render 117/117). **BT** (a021a3ca — 13 owned Go bricks: all build+vet clean, 11/13 gofmt+tests PASS; conductor-reconciled findings: containers TestIdleShutdown_TouchResets timing-flaky [ROOT CAUSE now FOUND — fire() lacks a lastTouch re-validation guard → Go

AfterFunc+Reset stale-fire race; fix needs a clock-injection test seam, tracked; unproven inline fix reverted per §11.4.115]; llm_orchestrator 6 + vision_engine 17 gofmt = the known deferred-mirror pair). **SR** (970fac0f — adversarial security review of O-impl headers: GO-WITH-FIXES, **C1 Critical CONFIRMED** — api-client.ts default baseURL http://localhost:8080 vs Tier-C connect-src 'self' breaks the Manager UI off-localhost; fix = relative default + re-embed [item K], BLOCKING non-localhost deploy, NOT loosening CSP; I1 HSTS-behind-proxy = operator trusted-proxy decision; I2/I3 minor/tracked). **C-impl** (512df0eb — ota-manager 9 v1 routes wired + **85** → **0 tsc**, vitest 36/36, conductor-verified; BUG-1 telemetry model-drift disclosed [pre-existing, contract decision]). - **§11.4.84 INCIDENT (recovered forward, no loss)** — my docs-only 9d21dd6a swept in 3 clients/deletions C-impl had staged with git rm (subagent-git violation §11.4.20/§11.4.70) because commit_all.sh --paths does a bare git commit that snapshots the whole index (item E wrapper bug — now ELEVATED to important). Recovered by completing C-impl forward as 512df0eb (§11.4.113 no-force-push; coherent tsc-0 tip restored, all mirrors 0/0). Full record: docs/research/incident_1184_paths_leak_20260710/INCIDENT.md. Prevention: fix item E to git commit -- <paths>; tighten subagent prompts to forbid git rm; index-clean precheck before every --paths commit (now habitual).

Latest session (2026-07-09, late) — OpenDesign adoption COMPLETE (both frontends) + hardening

Operator directive: continue the endless autonomous loop with 3-4 parallel subagents on real evidence, no bluff; keep improving OpenDesign (nexu-io/open-design). Executed the entire vendoring plan end-to-end; 11 commits, all pushed 4/4 FF (no force §11.4.113), every review that raised a finding iterated to a zero-finding GO (§11.4.134) before commit.

OpenDesign adoption — DONE on both web frontends: - design-systems/helix-ota/ (35035ba4) — OpenDesign-schema brand token package (manifest + tokens.css 56 props light+dark + tailwind-v4.css byte-exact with OpenDesign renderTailwindV4Css), palette derived from ota-manager's index.css. Reviewed GO. - **ota-manager** (74b94bb8) — vendored tokens byte-identical; FIXED the theme-toggle bug (store never wrote a DOM class → base dark palette stuck; now applyThemeClass writes .light/.dark + data-theme from setTheme/toggleTheme/onRehydrate, + jsdom unit test). Pixel-proven: light vs dark = 98.96% differ. - **dashboard** (4c6b201d base + 444b68f4 completion) — vendored tokens; added a REAL light/dark theme

(theme.ts: data-theme + localStorage + prefers-color-scheme seed, initTheme before render) + header toggle; repointed ALL 27 live screen-hex across 8 screens → var(--token) (9 justified fixed brand-chrome hex kept in the header). Controller test-covered (theme.test.tsx 13 + AppShell.test.tsx RTL). test:run 107, e2e:hostrender 45 (both themes, self-validated oracles), card #ffffff → #020817 dark-surface pixel proof.

Hardening landed alongside: - UI-surface audit + WCAG contrast

(961ec31c) — ota-manager+dashboard ADOPTED, server N/A, Android agents N/A/headless; measured contrast fails: dark --danger 2.00:1, light --warn 1.92:1, --success text 3.1:1 (proposed re-vendor recorded, NOT applied). - **ota-manager RED-suite restored** (28ce6fd6, §11.4.124/§11.4.114) — commit 94246322 had mistakenly deleted 18 camelCase hook re-export shims (bundled into a dist/ cleanup), breaking 4 test files; restored from git history (byte-match) + fixed a latent refetch → refetchStats ReferenceError; vitest 4-fail → 9-pass/36. - **Typecheck gate fixed** (94fb10a2, §11.4.120) — tsconfig.node.json invalid project-ref made tsc bail before checking source (why the refetch bug slipped); now functional, surfaces 118 pre-existing errors (tracked follow-up; ~57 on the dead unrouted pages). - **Guard-hook false-positive root-caused** (6466edc2, §11.4.102) — the §11.4.109 PreToolUse guard's OUTER regex spans any git...push across newlines + INNER matches any -f including benign flags → blocks legitimate multi-line commits. Fail-closed (safe). Fix deferred to §11.4.26 constitution workflow (evidence + validated proposal in FINDINGS.md).

Latest session (2026-07-09) — Constitution e60cbde adoption + UI/UX/OpenDesign audit

Operator directives this session: (1) fetch+pull latest constitution submodule + nested deps, adopt all new tech/rules ASAP; (2) continue the endless autonomous loop with 3-4 parallel subagents on real evidence, no bluff; (3) answer whether Helix OTA has OpenDesign-refined production UI on all platforms.

Landed + pushed 4/4 FF (no force §11.4.113), commits bb3b4189 (semgrep meta-test deletion, split off by a git add pathspec fatal) + 634fcb50 (main batch, 29 files +3485/-110): - **Constitution** fc4e9b8 → e60cbde (59 commits); nested engines pulled (token_optimizer @c0591b5, session_orchestrator @6961c99). Parent pointer bumped. - **Carriers CLAUDE/AGENTS/GEMINI** (.md+HTML+PDF §11.4.65): appended §11.4.167-174, 176-186, §12.12 (pure append, 0 deletions). - **§11.4.166 REPEALED reconciliation** (§11.4.120, not fake-pass):

removed CM-SEMGREP-WIRED gate + CM-COVENANT-114-166
propagation + `_semgrep_scan_check` in `commit_all.sh` + the `semgrep`
meta-test; **added** propagation gates 167-174/176-186/§12.12 to
`pre_build`. - **§11.4.109 anti-forgetting** wired: `.claude/settings.json`
PreToolUse guard-hook (blocks force-push/sudo/host-power/raw-
emulator at the tool boundary) + `docs/AGENT_GUARDRAILS.md`
(preamble+checklist) + renamed guard meta-test (26/26 bluff-proof). -
Fixes: `coverage_extra_test.go` `execStubMu` mutex → ETXTBSY
fork+exec fd race (golang/go#22315; 20/20 -count, 10× -race clean);
`guard_benchmark_baseline.sh` GUARD-SKIP when benchstat absent
(regression 9/9); `export_docs.sh` +weasyprint PDF engine (pandoc 3.10
EXIT-0, genuine PDF 1.7 — a haiku delta-reviewer's NO-GO on this was
refuted by captured same-conditions evidence per §11.4.7, see `qa-`
`results/delta_review_20260709/refutation.md`). - **UI/UX audit answer**
(docs/research/ui_ux_opendesign_audit_20260709/FINDINGS.md): NO —
Helix OTA is NOT OpenDesign-refined. TWO React frontends exist
(`clients/ota-manager` `shadcn/Tauri`; dashboard hand-rolled+Playwright/
axe); OpenDesign (§11.4.162) not installed in either; host-render visual-
proof (§11.4.170) unmet in both. The project CLAUDE.md “§11.4.162
latent” note is stale. - Validation: `pre_build` PASS, inheritance PASS,
regression 9/9, meta 6/6 bluff-proof, device 10× deterministic;
independent review GO.

Three parallel streams COMPLETE (§11.4.147 registry: A/B/C all complete), evidence committed: - **A — new-tech engine adoption** → `docs/research/new_tech_adoption_20260709/ADOPTION_PLAN.md`. Finding (§11.4.6/§11.4.124): server has NO LLM request path today → wiring either engine now = dead code. **token_optimizer** = adopt-as-available (first use: deterministic `log_triage` over the §11.4.128 recording corpus at first AI feature); **session_orchestrator** = needs-review (its `claim`+`scheduler` are the §11.4.176/§11.4.119 single-owner device-claim primitive — a prototype target for parallel device testing). Both build+test GREEN. Neither operator-blocked. §11.4.141 token-efficiency wins are separate Claude-Code config. - **B — server health** → `docs/research/server_health_20260709/REMEDIATION.md`. go build/vet/gofmt/test all GREEN, 15/15 pkgs (forced -count=1 non-cached). **No fix required** (zero-finding tree; correctly changed nothing per §11.4.102). Tracked gap unchanged: `internal/api/manager-dist` has no `_test.go`. - **C — OpenDesign + §11.4.170 harness** → `docs/research/ui_ux_opendesign_audit_20260709/OPENDSIGN_PLAN.md`. Recommends **clients/ota-manager canonical** (already has the token/dark-mode arch OpenDesign feeds; dashboard would be a rebuild; dashboard's

Playwright/axe e2e is portable). §11.4.170 harness spec: Storybook 8 + addon-themes × Playwright toHaveScreenshot() golden-diff + Tesseract-OCR layout oracle, self-validated golden fixtures (§11.4.107(10)).

BOTH OPERATOR DECISIONS RESOLVED (2026-07-09): 1. Canonical frontend → KEEP + IMPROVE BOTH (clients/ota-manager + dashboard). Nothing retired (§11.4.122 satisfied). OpenDesign adopted across both. 2. **OpenDesign = nexu-io/open-design** (git@github.com:nexu-io/open-design.git) CONFIRMED by operator.

OpenDesign ground truth (W1 evidence, docs/research/ opendesign_integration_20260709/INTEGRATION_GROUND_TRUTH.md): it is NOT a CSS-token npm package — it is a local-first design PRODUCT (Electron + od daemon + Next.js UI) exposing itself to coding agents over stdio-MCP + od CLI, shipping 153 design-system token packages as static files. **Adoption = combination:** (author-time) build daemon + wire its MCP plugin into Claude Code; (build-time, what ships) vendor a design system's static tokens.css (~56 :root custom props) + tailwind-v4.css (Tailwind-v4 @theme, matches ota-manager's Tailwind 4), light+dark first-class. Do NOT consume @open-design/components (private, React-18.3.1-pinned ⇒ conflicts with ota-manager React 19). §11.4.74 path: author a design-systems/helix-ota/ brand package. Verdict NEEDS-REVIEW (heavy product; od daemon = network service ⇒ rootless/containerized §11.4.161/§11.4.173; keep React-18 components out).

§11.4.170 host-render harnesses LANDED on BOTH frontends (W2/W3, independent-review GO each): - **ota-manager** (docs/qa/20260709-ota-manager-hostrender/, harness clients/ota-manager/visual/): LoginPage × {light,dark} rendered host-side (Playwright+Vite+Tailwind4+pixelmatch+**Tesseract OCR**); dual oracle image-diff good 0% / bad flagged both themes + layout oracle flags collapsed-submit; self-validation image_diff_analyzer_sound+layout_analyzer_sound=true (golden-good/golden-bad §11.4.107(10)); reviewer re-ran byte-identical, GO. - **dashboard** (docs/qa/20260709-dashboard-hostrender/, harness dashboard/hostrender/): Login host-rendered (vite-only, backend-independent), pixelmatch good 0% / bad 13% + layout oracle + committed golden REJECTs mutation; reviewer's adversarial negative-control (mutation-disabled → self-checks correctly FAIL) proves non-rubber-stamp, GO. Existing suite baselined: vitest 93/93, Playwright 22/1-pre-existing-flake, axe 0 critical/serious.

NEW TRACKED BUG (real, surfaced by W2 host-render proof — §11.4.170 working as designed): ota-manager's ui-store theme value is **never wired to a DOM .dark/.light class** (ui-store.ts:27-32 mutates zustand only; topbar.tsx swaps just the Sun/Moon icon; no document.documentElement.classList writer in src/) → the toggle changes only the icon, :root(dark) always applies. To be FIXED by the OpenDesign light/dark wiring.

§11.4.170 ledger / Minor follow-ups (tracked, non-blocking): (a) OCR oracle not yet mutation-validated on ota-manager — add an OCR golden-bad; (b) coverage is 1 screen/state on each frontend — remaining screen×state×{light,dark} matrix owed; (c) dashboard has NO dark mode in code (light-only proven, honest gap); (d) pre-existing ota-manager tsconfig TS6306/6310 (tsconfig.node.json lacks composite:true) — pre-existing, unrelated.

NEXT (feature/opendesign-adoption, §11.4.167): author design-systems/helix-ota/ brand tokens (light+dark, brand colors) → vendor tokens.css+tailwind-v4.css into BOTH frontends → **wire the ota-manager theme toggle to the DOM class + add dashboard dark mode** → prove light+dark via the two harnesses → expand the screen×state matrix + add OCR golden-bad. Also queued (non-UI): TEST-COVERAGE Phase 1 remainder (2026-06-23 signed-pipeline + challenges-bank still UNTRACKED, needs re-validation §11.4.108); commit_all.sh --paths deletion-paths spec fix. **OPERATOR: rotate the posted password (§11.4.10).**

Latest session (2026-06-23) — Comprehensive test-coverage + anti-bluff program (Phase 0 DONE + Phase 1 mostly done)

Continuation of the operator mandate (genuine 100% real coverage by every test type + Challenges + HelixQA vs the real running system, anti-bluff everywhere, rock-solid physical proof, no false positives). Honest framing (§11.4.6): multi-phase program — docs/research/MASTER_TEST_COVERAGE_PLAN_20260623.md (Rev 2) holds the plan + the **live coverage ledger**. This round drove **Phase 1 risk-descending (§11.4.132)** deep; all items below have real captured evidence committed + 4-remote synced (HEAD 21338527), except the two explicitly marked IN FLIGHT:

- **Integration (pgx)** — store **85.5%** / rollout **83.1%** MEASURED via real -tags integration podman+Postgres run (docs/qa/20260623-postgres-integration/).

- **F-ANTIBLUFF-LIB** — tests/lib/anti_bluff.sh
ab_pass_with_evidence per-PASS §11.4.69 helper, mutation-proven self-test + standing guard (docs/qa/20260623-antibluff-lib/).
- **F-CLUSTER real-system boot** — server/deploy/system.compose.yml + tests/lib/boot_real_system.sh boot the REAL ota-server + real Postgres → /readyz → 200 + DB-backed admin JWT login (docs/qa/20260623-real-system-boot/); two §11.4.102 prod fixes (startup retry-with-backoff, harness clean-slate).
- **e2e vs REAL DB** — challenge_operational **39/39 PASS** against live Postgres (DB-proof: 14 audit_logs rows, real end-of-run delete; docs/qa/20260623-e2e-live-system/).
- **Security trust-boundary 4/4 vs live** — runtime proof the **request-supplied artifact pubkey is IGNORED** (server-config key only); throwaway test secrets redacted (§11.4.10, commits 84f32a66/1d71e182). Evidence docs/qa/20260623-trust-boundary-live/.
- **Go fuzz** — 4 targets, **10.8M execs / 0 crashers**, property-based (round-trip / antisymmetry / hex-oracle); docs/qa/20260623-fuzz/.
- **HTTP load** — p99 **14.32ms** @ 5,540 req/s, zero 5xx; docs/qa/20260623-http-load-live/.
- **Chaos (§11.4.85) 4/4 survive+recover** — postgres-kill → reconnect (validates main.go retry fix, no corruption), malformed/oversized → 400, 12-race idempotent register → exactly-one-device, 400-conn churn → recovers; docs/qa/20260623-chaos-live/.
- **Benchmark** — benchstat baseline registry + negation-proven guard (7 benches; thresholds calibrated on measured variance); docs/benchmarks/ + docs/qa/20260623-benchmarks/.
- **Android JaCoCo** — wired both bricks: ota-update-engine-bridge **LINE 100%** (113/113), ota-android-agent **LINE 91.18%** (json-codec branch 55.6% → **100%/100%** via 54 new tests); docs/qa/20260623-android-jacoco/ + docs/qa/20260623-json-coverage/.
- **F-METAGATES + propagation-gate batch** — meta-test framework wired into pre-build; **ALL 14 propagation gates now §11.1-paired** (data-driven from pre_build source → new gates auto-covered); §11.4.166 semgrep fail-open FIXED; one real §11.4.50 flake found+fixed (10/10 det). docs/qa/20260623-metagates/ + docs/qa/20260623-propagation-metagates/.
- **Independent review (§11.4.165)** — the batch passed an independent verifier that **found + fixed a tautological restore-integrity bluff** in tests/meta/lib_metatest.sh.
- **IN FLIGHT (not yet committed, §11.4.6): signed-pipeline-vs-live** (tests/e2e/pipeline_signed_live.sh — a local run is **15/15 PASS**: signed upload → release → deploy → rollout → device-poll-receives-signed-update vs live system, but docs/qa/20260623-signed-

pipeline-live/ is UNTRACKED) and the Challenges-bank dry-run (docs/qa/20260623-challenges-bank/, UNTRACKED). The conductor lands these.

NEXT (Phase 1 remainder + Phase 2, risk-ordered): (1) commit the in-flight signed-pipeline-vs-live + challenges-bank evidence; (2) security **saturation / DDoS** (rate-limit flood vs live); (3) **on-device agent A/B** (drive the two JVM bricks on the live Cuttlefish cvd, or RK3588 when reachable); (4) **Phase 2** — wire the Go cmd/helixqa orchestrator + new OTA Challenges (bad-sig-rejected, request-key-ignored, telemetry-schema, rollout-staged+halt, chaos) against the live system; (5) functional §11.4.165 media/vision gate (the §11.4.163 pipeline) beyond the now-bluff-proof grep-gate layer. Suites: regression 8/8 + meta 5/5 GREEN. cvd still live on nezha. **OPERATOR: rotate the posted password (§11.4.10).**

Prior session (2026-06-23) — Comprehensive test-coverage + anti-bluff program (Phase 0 + Phase 1 start)

Operator mandate: genuine 100% real coverage by every test type + Challenges + HelixQA vs the real production system on the configured cluster, anti-bluff everywhere, rock-solid physical proof, no false positives. Honest framing (§11.4.6): this is a multi-phase program — docs/research/MASTER_TEST_COVERAGE_PLAN_20260623.md holds the plan + a **live coverage ledger** (updated as each item lands). Landed this round, all real captured evidence, committed + 4-remote synced:

- **Push-all** — every owned submodule + main current on all configured mirrors (constitution ×8 etc.).
- **3 research audits + master plan** (docs/research/): coverage-audit (Go layer mutation-proven anti-bluff; flipping the ed25519 sig-check killed 11 tests), cluster-and-system (pgx Repository IS implemented; “cluster” aspirational for OTA = thinker), challenges-helixqa-antibluff (Challenges+HelixQA powerful but unwired vs ota-server; anti-bluff on ~2-3 of 17 gates).
- **Integration coverage CAPTURED** (docs/qa/20260623-postgres-integration/): real -tags integration pgx run on nezha — store 47.9% → 85.5%, rollout 28.2% → 83.1%.
- **F-ANTIBLUFF-LIB** (tests/lib/anti_bluff.sh, docs/qa/20260623-antibluff-lib/): the §11.4.69 per-PASS ab_pass_with_evidence helper + mutation-proven self-test + standing guard.
- **F-CLUSTER real-system boot PROVEN** (docs/qa/20260623-real-system-boot/): server/deploy/system.compose.yml + tests/lib/boot_real_system.sh boot the REAL ota-server + real Postgres on

thinker → /readyz → 200 + DB-backed admin JWT login. Two §11.4.102 production fixes: server startup retry-with-backoff (was log.Fatalf on first pg ping — compose/k8s crash-loop), harness clean-slate do_down (exit-125 recreate collision).

- **e2e vs REAL DB** (docs/qa/20260623-e2e-live-system/): challenge_operational **39/39 PASS** against live Postgres (DB-proof: 14 audit_logs rows persisted, device_groups=0 end-of-run-delete real). Finding: 4/5 e2e suites self-hosting-by-design (must own the artifact pubkey to sign) → signed-pipeline-vs-live needs a caller-pubkey F-CLUSTER mode.
- **F-METAGATES** (tests/meta/, docs/qa/20260623-metagates/): meta-test framework wired into pre-build; **4 gates now bluff-proof** via paired §1.1 mutate → FAIL → restore → PASS (coverage-minimum, semgrep-wired, 2 regression guards, evidence-lib); **§11.4.166 semgrep fail-open FIXED** (semgrep on PATH → gate passes); a real flake found+fixed (§11.4.50, 10/10 det).

NEXT (Phase 1 risk-ordered, all documented in the master plan): signed-pipeline-vs-live (caller-pubkey F-CLUSTER mode) · security trust-boundary negatives + go test -fuzz · HTTP load/latency p50/p95/p99 (wire tools/loadtest) · Android JaCoCo + on-device A/B · remaining ~14 anchor-greps → functional/paired gates · Phase 2 Challenges+HelixQA Go orchestrator vs live system. Suites: regression 8/8 + meta 4/4 GREEN. cvd still live on nezha. **OPERATOR: rotate the posted password (§11.4.10).**

Prior session (2026-06-23) — Cuttlefish Tier-2 REAL Android A/B VERIFIED on nezha (F112/F55, OTA-003 closed)

TERMINAL GOAL MET (honest §11.4.6 — real captured evidence). A real ~1 GB OTA payload was applied through update_engine to a live Cuttlefish cvd (build 15660610, aosp_cf_x86_64_only_phone, Virtual A/B + verity enforcing, 15 A/B partitions) on nezha, driven autonomously as milosvasic over adb -s 127.0.0.1:6520 (no host sudo for the A/B flow): onPayloadApplicationComplete(kSuccess) → UPDATE_STATUS_UPDATED_NEED_REBOOT (115 s) → reboot slot flip _a→_b (VAB merge merging→none, _b marked successful) → forced-bad slot _a (bootctl set-slot-as-unbootable + bounded 256 KB inactive-slot boot_a write, §11.4.133) rejected → device booted known-good _b. The OTA

payload was obtained with NO credentials (androidbuildinternal pre-signed GCS URL storage.googleapis.com, 1003473429 B, md5 d90870a9a6eece3868520d7fd3f098c — size+md5 verified before apply).

- **Evidence:** docs/qa/20260623-cuttlefish-tier2-ab/REPORT.md (+ apply_full.log, slot_flip.log, rollback.log, corrupt_dd.txt, ab_facts.txt, ...) — read-the-screen verified per §11.4.158 (REPORT §7).
- **Status:** F112 PARTIAL → VERIFIED; F55 (Tier-2 driver) OPERATOR-BLOCKED → VERIFIED (Status.md rev 21, Status_Summary rev 13; VERIFIED 25 → 27, PARTIAL 4 → 3, OPERATOR-BLOCKED 2 → 1).
- **Validator:** tests/emulator/tier2_cuttlefish_ab.sh HONEST STATUS → VERIFIED on nezha 2026-06-23; UNCONFIRMED items resolved to FACT (bootctl/update_engine_client root-only; no-creds androidbuildinternal ota-<BID>.zip; Virtual A/B not legacy; corrupt = set-unbootable + bounded boot_a write); new running-container --serial/HELIX_CF_SERIAL mode (topology B) added; bash -n / sh -n clean.
- **Regression guard:** tests/regression/guard_cuttlefish_ab_proven.sh GREEN (§11.4.135; asserts slot_flip/rollback/kSuccess evidence + validator VERIFIED header, RED on stripped proof).
- **Full journey (provenance):** curl-download-fail → resumable wget-c recovery → 27.6 GB single-stage image → slim 1.11 GB prebuilt-deb path (containers 54aa9b2) → operator privileged launch (cf-launch.sh) → cvd booted → this A/B PASS. **cvd left running on nezha.**
- **Honest boundary (§11.4.3/§11.4.112/§11.4.133):** Cuttlefish is the hardware-free A/B proxy; the RK3588 boards (F113) stay control-plane-only by operator decision (native A/B is Cuttlefish-only); bootctl/update_engine_client are root-only on the cvd (FACT).

Prior session (2026-06-23, earlier) — Cuttlefish slim image built + launch command VERIFIED (asset-feed + launch_cvd proven)

Cuttlefish moved from runbook-ready to **launch-command-VERIFIED** (honest §11.4.6 — still NOT a real-A/B PASS):

1. **Slim image built + committed** — helix-cuttlefish:slim built rootless on nezha at **1.11 GB** (vs 27.6 GB single-stage from-source) via the upstream runner-prod **prebuilt-.deb** path (cuttlefish-base/cuttlefish-user **1.54.1** from us-apt.pkg.dev/projects/android-cuttlefish-artifacts android-cuttlefish main, NO Bazel/cargo).

cvd version 1.54.1 executes. containers submodule 54aa9b2; parent pointer **659c2326**. Saved to /tmp/cf-slim.tar (1.03 GiB) for rootless → rootful load.

2. **Assets staged + integrity-verified** — nezha ~/cf-staging/, build **15660610** aosp_cf_x86_64_only_phone-userdebug: cvd-host_package.tar.gz (898828370 B, gzip-valid) + img.zip (1163637538 B, unzip-valid; original curl truncation recovered via resumable wget -c).
3. **Runtime model FACT (§11.4.28)** — image ships modern cvd; launch_cvd is extracted at RUNTIME by the entrypoint from the host package (CF_HOST_PKG_URL/CF_IMG_URL via file:// over the mounted /staging), NOT baked.
4. **PRE-VERIFY PROOF (§4.5)** — a rootless build-matched fetch-test ran the entrypoint file:// asset-feed end-to-end: fetching device image (super.img + boot/init_boot/vbmeta extracted) → fetching host package (./bin/launch_cvd present) → launching cvd via ./bin/launch_cvd → **launch_cvd RAN**, assembled the cvd-1 config, Launcher Build ID: 15660610; then EXPECTED rootless VIRTUAL_DEVICE_BOOT_FAILED run_cvd returned 10 (no /dev/kvm/bridge). Asset-feed + launch_cvd discovery + config assembly **PROVEN**; only the privileged boot remains. Evidence: docs/qa/20260623-cuttlefish-launch-verified/REPORT.md.
5. **VERIFIED operator privileged launch** (runbook §2.3): sudo modprobe vhost_vsock → sudo podman load -i /tmp/cf-slim.tar → sudo podman run -d --name cuttlefish --privileged --network host --device /dev/kvm ...vhost-vsock ...vhost-net ...vsock ...net/tun -v /home/milosvasic/cf-staging:/staging:ro -e CF_HOST_PKG_URL=file:///staging/cvd-host_package.tar.gz -e CF_IMG_URL=file:///staging/img.zip helix-cuttlefish:slim → sudo podman logs -f cuttlefish. Rootless → rootful gap closed by the save|load step (§11.4.161 exception — privileged run is rootful).

HONEST BOUNDARY (superseded 2026-06-23): this prior-session boundary said F112/OTA-003 was integration-pending. That has since been DONE — the operator ran the privileged launch and the agent drove tier2_cuttlefish_ab.sh, capturing the real A/B apply + slot-flip + auto-rollback evidence (see the latest-session block above; docs/qa/20260623-cuttlefish-tier2-ab/). F112/F55 are VERIFIED.

Prior session (2026-06-22, late) — distribution mechanism, infra fixes, amber onboarded, Cuttlefish runbook-ready

LATE UPDATE (2026-06-22, distribution path now fully VERIFIED end-to-end on thinker — F114): A fully-automated, non-dry-run `HELIXTRACK_REMOTE_HOST=thinker.local bash scripts/distribute_stack.sh` is now **PROVEN GREEN**: it BUILT the helixtrack-core image on thinker (rootless podman-compose) from the Go 1.24 Dockerfile, brought the stack up, and a fresh container reported `podman ps: helixtrack-core Up (healthy) + helixtrack-postgres Up (healthy)`, with `curl -sf http://localhost:8080/health → 200 {"status":"ok"} (FailingStreak=0)`. Evidence `docs/qa/20260622-222645-distribute-thinker-FULLY-GREEN/`. The fix chain that closed the Rev-19 blockers: `distribute_stack.sh` (provider-preference for podman-compose + nested-mkdir + build-before-up + down-before-up idempotency); `containers/compose.helixtrack.yml /health healthcheck` (submodule `dcef56d`); HelixTrack Core Dockerfile `golang:1.24` + restored gutted source (`3c62217/3483699`) + `curl` in the runtime image (`d0f4bfb`). **F114 is now VERIFIED** (Status.md rev 20, Status_Summary rev 12; VERIFIED 24 → 25, PARTIAL 5 → 4). **F115 (amber docker-fallback) and F116 (setsid persistence) stay PARTIAL** — neither real-deploy/persistence run has been executed yet.

Docs + infra consolidation (honest §11.4.6 — no new PASS claimed):

- 1. Cuttlefish bring-up RUNBOOK-READY (F112 / OTA-003)** — new `docs/design/CUTTLEFISH_NEZHA_RUNBOOK.md`: the exact operator-vs-agent step split for the real Cuttlefish A/B run on nezha (which has NO passwordless sudo). **Operator** runs the 3 privileged steps — (§2.1) `verify/load vhost_vsock/vhost_net + create /dev/vsock` if absent, (§2.2) one-time group membership, (§2.3) the `sudo podman run --privileged --network host --device /dev/kvm ...vhost-vsock ...vhost-net ...vsock ...net/tun -v ~/cf-staging:/staging cuttlefish:latest`. **Agent** drives the rest — build the image (rootless), extract the staged assets (`~/cf-staging/cvd-host_package.tar.gz` 898 MB + `img.zip` 1.16 GB), `launch_cvd --daemon`, the `tier2_cuttlefish_ab.sh` A/B-slot-flip + auto-rollback validation, evidence capture to `docs/qa/<run-id>/`. Every still-UNCONFIRMED: item (exact device mounts, Virtual-A/B-vs-legacy, the corrupt-slot mechanism) is verified at run time, never guessed. **HONEST BOUNDARY: this is a runbook to EXECUTE — NOT a real-A/B PASS.** F112 stays PARTIAL / integration-pending until the runbook runs with captured slot-flip + rollback evidence. Built

under the §11.4.161 documented exception
(CUTTLEFISH_ROOTFUL_EXCEPTION.md).

2. **Distribution mechanism + amber onboarded (F114/F115)** —
distribute_stack.sh (helix layer, §11.4.28 — NOT inside the generic
containers submodule) deploys the HelixTrack stack over SSH +
remote rootless podman compose. thinker.local = LIVE rootless-
podman target; amber.local onboarded 2026-06-22 (SSH key
installed + docker present) with a **§11.4.161 operator-authorized
docker fallback** (HELIX_ALLOW_DOCKER_FALLBACK=1, default-OFF
rootless-or-nothing, §11.4.112 documented constraint = no rootless
podman on amber yet); nezha.local is read/import-only.
Companion doc docs/scripts/distribute_stack.md updated (Rev 2)
with the docker-fallback section.
3. **Remote-emulator full-detachment fix (F116, §11.4.144)** —
scripts/boot_android_emulator.sh remote launch wrapped in
setsid nohup ... </dev/null >log 2>&1 & (own session + process
group) so an interrupted launching SSH session no longer kills the
remote emulator (closes the known robustness gap noted in Rev 5).
Companion doc docs/scripts/boot_android_emulator.md Rev 2.
Honest boundary: on-target persistence-after-reboot verification
stays operator-attended.
4. **commit_all cascade-push fix (F117)** — commit_all.sh/push_all.sh
portable mkdir lock + honest exit + per-remote fetch timeout; four-
upstream fan-out per §2.1/§11.4.88.

Docs: 4 new Status feature rows (F114–F117, all VERIFIED), Status.md
Rev 18 + Status_Summary.md Rev 10, runbook + 2 script companion
docs + their html/pdf/docx exports regenerated, docs_chain features-
status synced.

Operator action items (carried + new): (1) **Cuttlefish on nezha** —
run the VERIFIED privileged launch block in docs/design/
CUTTLEFISH_NEZHA_RUNBOOK.md §2.3 (the slim image + assets are ready;
only the operator's sudo modprobe vhost_vsock + sudo podman load -i /
tmp/cf-slim.tar + sudo podman run --privileged ... remains) to unblock
the real Android A/B run — the agent then drives the A/B validation; (2)
amber — install rootless podman to retire the §11.4.161 docker-
fallback exception (preferred over the fallback); (3) Cuttlefish on-target
persistence verification is operator-attended; (4) physical RK3588
boards remain NON-A/B (control-plane validation only).

Prior session (2026-06-22, evening) — Cuttlefish Tier-2 container path + real RK3588 control-plane validation

Three new real capabilities landed (honest §11.4.6 — boundaries stated, not overclaimed):

1. **Cuttlefish Tier-2 containerized path (F112)** — new pkg/cuttlefish cvd-lifecycle wrapper in the containers submodule (cuttlefish.go / accel.go / cleanup.go / health.go / types.go / entrypoint.sh / Containerfile). go test -race ./pkg/cuttlefish/ = ****30 PASS**
 - 1 honest topology SKIP** (no Linux+KVM on this macOS host). Rootless cannot host Cuttlefish, so a narrowest-scope **rootful-privileged documented exception** is recorded — docs/design/CUTTLEFISH_ROOTFUL_EXCEPTION.md (§11.4.161 documented exception via §11.4.112; image build + artifact fetch stay rootless, only launch_cvd is privileged). **HONEST BOUNDARY: the container path is BUILT + unit-tested — it is NOT yet a real-A/B PASS.** The real end-to-end Android update_engine/AVB/dm-verity A/B run is **integration-pending** on nezha Linux+KVM (assets staging; privileged launch_cvd operator-gated). Native A/B fidelity is this path's job once provisioned.
2. **Real RK3588 hardware control-plane validation (F113)** — evidence docs/qa/20260622-rk3588-controlplane/REPORT.md. Server cross-built linux/amd64, run **rootless** on nezha (uid 1000). **Device B** (Ethernet, serial 1acdceab90248933) **PASS**: board-originated GET /healthz 200, GET /api/v1/client/update 204 (no active deployment — correct), POST /api/v1/client/telemetry 202, and sink-side GET /devices/by-hardware/1acdceab90248933 → update_state=success (the board's own telemetry mutated server state). **Device A** (Wi-Fi, 19bbb528a1dbbc4d) honest topology **SKIP** — VPN tun1 full-tunnel / Wi-Fi AP isolation (busybox nc to both :18080 and :22 time out → blocked network path, captured root cause, NOT a Helix defect). **HONEST BOUNDARY: both boards are NON-A/B** (single-slot, no update_engine) → this validates the control plane on real hardware, NOT native A/B apply. **ZERO device state changes** (§11.4.122/§11.4.133).
3. **Distribution repoint** — container distribution targets now thinker.local (live) + amber.local (SSH-key-pending); nezha.local is read/import-only.

Operator action items: (1) **amber.local** — install the SSH key (ssh-copy-id to amber) to bring it live as a distribution target; (2) **Cuttlefish on nezha** — the privileged launch_cvd needs operator sudo (+ reboot +

~30 GB fetch_cvd) to unblock the real Android A/B run (F112 integration-pending); (3) **assets staging in progress** for the Cuttlefish Tier-2 run; (4) the **physical RK3588 boards are NON-A/B** (single-slot) — real on-device A/B fidelity is the Cuttlefish path's job, not these boards (control-plane validation only on them).

Prior session (2026-06-22, daytime) — “do everything workable” sweep

All autonomous items GREEN with real captured evidence (no bluffs): - Test sweep GREEN (server 11/11 + 4 Go submodules 3/3, -race 0); **gofmt fixed** (13 files); pre-build gates PASS; docs_chain in-sync. - **Local QEMU A/B OTA 6/6 GREEN** (smoke/boot/slot-switch/rollback/OTA-apply) — evidence docs/qa/20260622T07*. Fixed a real §11.4.115 RED-mode polarity isolation bug in ab_rauc_verity.sh (RED×2+GREEN×2 deterministic). - **10 server-feature recordings regenerated**, vision-verified (203 HTTP assertions) — docs/qa/20260622-server-recordings-regen/; Status.md §11.4.153 reconciled to durable paths. - **§11.4.166 Semgrep**: propagated §11.4.160-166 into CLAUDE/AGENTS/GEMINI; tokenless local scan wired into commit_all.sh; constitution pin → 09d8940 (adds docs/semgrep/TOKEN_SETUP.md); 7 findings triaged → **0 remaining** (TLS MinVersion fix + cited suppressions). - Submodule push parity closed (ota-update-engine-bridge, ota-android-agent); GitFlic “blocker” disproven; §11.4.30 transient qa-results/untracked+ignored (232 files). - nezha AVD boot proven; real Android A/B = honest **operator-attended SKIP** (Cuttlefish unprovisioned — needs sudo+reboot+fetch_cvd).

Operator action items: (1) Semgrep SEMGREP_APP_TOKEN — follow constitution/docs/semgrep/TOKEN_SETUP.md (semgrep login) to silence the MCP hook (optional; tokenless gate already compliant); (2) provision Cuttlefish on nezha to unblock real Android A/B; (3) RK3588 board for OTA-004/F55/F56.

Known robustness gap (tracked, NOT yet fixed — §11.4.6/§11.4.123): scripts/boot_android_emulator.sh — the remote qemu/AVD on nezha stays tied to the launching SSH session and exits gracefully if that session ends mid-boot-wait (the nohup does not fully detach the remote process; the final SSH-tunnel/attestation step isn't reached on interrupt). Boot itself is PROVEN (emulator-5554, API 36, boot_completed=1, evidence qa-results/20260622T071848Z-nezha-android-ab/). Fix candidate: wrap the remote launch in setsid nohup ... </dev/null >log 2>&1 & (or a systemd-run --user --scope on nezha) for true detachment — deferred because on-target

persistence verification (re-boot + interrupt test, leaves remote state) is operator-attended; a blind change to the working boot path is forbidden per §11.4.1 without rock-solid proof.

Active items

ID	Title	Status	Type
OTA-003	Emulator Tier-2 — real Android A/B (update_engine/ AVB/dm-verity auto-rollback)	Completed (→ Fixed.md) — VERIFIED on nezha 2026-06-23, evidence docs/ qa/20260623- cuttlefish-tier2- ab/	Task
OTA-004	Emulator Tier-3 — real RK3588 / Orange Pi 5 Max vendor HAL, U-Boot slot-switch, dm- verity on real partitions	Operator- blocked	Task

Recently closed items

ID	Title	Status
OTA-021	HelixTrack bidirectional sync verification	Completed
OTA-020	Database migration test	Fixed
OTA-019	Build resource stats tracker	Completed
OTA-018	ApplyPort CLI + slot manager + Ed25519 verifier	Implemented
OTA-017	U-Boot corrupt-slot auto-rollback via bootcount	Implemented

ID	Title	Status
OTA-016	RAUC dd-apply to inactive slot with dm-verity	Implemented
OTA-015	A/B slot switch via U-Boot BOOT_ORDER	Implemented

Full issue details: docs/Issues.md · docs/Fixed.md · docs/Issues_Summary.md · docs/Fixed_Summary.md.

2. Server tests — all GREEN

All 13 testable packages pass (11 internal packages + chaos + stress suites):

```
ok internal/api
ok internal/config
ok internal/device
ok internal/deviceemu
ok internal/fabric
ok internal/health
ok internal/rollout
ok internal/store
ok internal/transport
ok tests/chaos
ok tests/stress
```

No-test-file packages (build-only): cmd/applyport, cmd/ota-device-emu, cmd/ota-server, tools/loadtest.

3. Emulator status

Property	Value
Host	nezha.local — Linux x86_64, 62 GB RAM, KVM
Image	Android API 36 (Android 16) — CZ_API36_Phone
Transport	ADB over SSH tunnel (reachable at emulator-5554 from nezha)

Property	Value
ADB local	No Android devices connected locally (emulator is remote via SSH tunnel)
LD_LIBRARY_PATH	/home/milosvasic/.local/lib
Cuttlefish Tier-2	Pending AOSP guest images

The HelixTrack API is accessible from the emulator via SSH tunnel. The CZ_API36_Phone image provides the standard Android 16 AOSP stack on an x86_64 KVM host.

4. What's running

- **Main stream:** OpenDesign adoption COMPLETE (both frontends); autonomous loop (§11.4.126) continuing on polish/hardening follow-ups (§5).
- **Wave-1 streams (M/P/R/K) — ALL LANDED + reviewed + committed** (d463ec3e/34f7dcf6/df2784ec/f553104f+95d8328e), each independently re-verified by the conductor before commit (§11.4.142): M's ratios genuine, P's 85-count re-run, R's 81/81 re-run + oracle-broadening reviewed sound, K's challenges fix green under -race -count=5 + FF-pushed to the brick's remotes.
- **Wave-2 streams (S/T/U/V) — ALL LANDED + reviewed + committed** (a8c12d9a/5a3e036a/870ca9ff/ca3860d8), each conductor-re-verified (§11.4.142): S's ratios re-run 38/38 + rounding-trap caught, T's tests re-run SKIP-OK + submodule integrated 11-behind → FF-pushed, U's 117/117 re-run, V's audit real captured suite.
- **Wave-3 streams (2 in flight at Rev 18):** W close V's top server §11.4.169 gaps — memory/heap-growth assertion for core handlers + a native Go Fuzz target (test-only, owns server build); Y extend ota-manager §11.4.170 host-render beyond LoginPage to the shipped /dashboard screen ×{light,dark}, with honest §11.4.3 SKIP-with-reason if it's too coupled to render (owns ota-manager build). Evidence only; conductor reviews + commits.
- **Recording directory:** \$HOME/Downloads per §11.4.158(D) (default; no project-level override)

5. Next actions (priority-ordered)

OpenDesign polish/hardening follow-ups (from the 2026-07-09-late session — all non-blocking):

A. WCAG contrast token re-vendor — DONE for dashboard

(dbc20d51 + cdce12c7, §11.4.170 re-proven 45/45). Applied values (all AA): dark --danger → #ef4444 (5.32), light --warn → #854d0e (6.85), light --success → #166534 (7.13), light --muted → #475569 (7.58), --border-strong #64748b added. Evidence docs/qa/20260709-wcag-token-revendor/EVIDENCE.md + ledger docs/research/

frontend_production_readiness_20260709/READINESS.md (Rev 2). A2.

NEW — ota-manager shadcn :root palette WCAG audit. The vendored OpenDesign tokens are INERT for ota-manager (shadcn HSL wins the cascade — A EVIDENCE.md §4), so ota-manager's shipped colors are still un-audited. Stream **M** audit DONE (d463ec3e): 38 pairs checked, 10 UI-boundary (SC 1.4.11) fails, 0 text fails, same-hue fixes proposed. Stream **S** DONE (a8c12d9a) — **A2 CLOSED for UI**

boundaries: applied same-hue AA fixes to --border/--input/--ring/--sidebar-border in both themes, all ≥3:1 (independently re-run 38/38 PASS), ota-manager host-render OVERALL PASS self-validated. S caught+corrected a rounding trap in M's 2-decimal proposed values (they recompute just under 3.00 at full precision) — used precise 4-decimal values. Honest gap: --sidebar-border proven by ratio only (LoginPage harness has no sidebar). Residual: light --danger #dc2626 = 3.81 on its own badge-tint (documented, not over-changed). B. **ota-manager type errors — Stream P DONE (34f7dcf6): 118 → 85.** 33

router-independent genuine bugs fixed (root cause: a types/api.ts re-export gap + real cache-key bugs verified against the Go server contract). The 85 remaining are ALL confined to the operator-gated router/unrouted-page cluster (routes/index.tsx, *-page.tsx, app-layout/sidebar react-router-dom shapes) — they await the tanstack-router reconciliation (item C). Evidence: docs/qa/20260709-ota-manager-typecheck-triage/. C. **Router-wiring of ota-manager feature pages — OPERATOR-GATED (§11.4.101). Decision brief READY (660e8e6d, Stream OB2):** docs/research/

operator_brief_ota_manager_router_20260710/BRIEF.md. Key facts: the 85 tsc errors are a MIX (router-API ~19 / hook-return-shape ~15 / API-type ~22 / toast 6 / select-form 10 / unused 8) — router migration alone fixes ~1/4. Pages are INTENDED shipping features (git a0552d8e + design spec §4), so **WIRE, not delete** (§11.4.124). Recommended: Option A (wire, as an isolated feature work-stream). **Operator UX decision needed:** which v1 routes/sub-routes ship. Do NOT auto-wire. D. **Guard-hook fix — §11.4.26 constitution workflow.** Tighten the force-push

regex per docs/research/guard_hook_false_positive_20260709/
FINDINGS.md (fuller split-on-separators + scoped-inner; minimal regex
has a documented `git -c k=v push false-negative`) + update the ≥20-
case hook test suite; push to all constitution upstreams. Operator-
aware. E. **§11.4.30 hygiene**: untrack `clients/ota-manager/dist/` (build
artifact) + gitignore — blocked on the `commit_all.sh --paths deletion-`
`paths spec` bug (a deletion path in `--paths` fatals the whole `git add`); fix
that wrapper bug first. Also gitignore `toPdfViaTempFile*` export
residue. **Still open** (the wrapper fix touches the very tool used for
every commit — do carefully, isolated, with independent review
§11.4.142). F. **Expand §11.4.170 screen×state matrix**. Stream **R DONE**
(df2784ec): dashboard now proves 9 screens ×{light,dark} (added
Deployments/Fleet/Groups/Overview; 45 → 81 host-render pass;
found+fixed a real layout-oracle substring bug). Stream **U DONE**
(870ca9ff): empty+error STATE variations for Releases/Fleet (81 → 117
host-render pass). ota-manager host-render now at 2 screens
(LoginPage + shipped /dashboard, 01947d8e); the remaining feature
pages are unrouted dead code pending the router decision C (not
honest gaps until wired). G. **OpenDesign author-time daemon** (od
MCP + Next.js UI) setup — rootless/containerized (§11.4.161/§11.4.173),
operator-review-gated (heavy product).

**Submodule-brick health follow-ups (from Stream K audit, docs/
research/submodules_health_audit_20260709/AUDIT.md):**

H. **challenges brick fix — DONE + committed (f553104f)**. Real `pkg/
challenge/result.go Result.RecordAction` data race (unsynchronized
append, 30 concurrent callers lost updates) fixed with an unexported
mutex (JSON byte-unchanged); a §11.4.1 chaos-test FAIL-bluff (`tests/
chaos` built a path from 500 NUL bytes — illegal) fixed to a valid long
nested path + a graceful-degrade subtest. Verified `-race -count=5 PASS`,
`brick go test ./... rc=0`; FF-pushed to the brick's remotes (0-ahead/0-
behind everywhere), parent pointer bumped to 5bac429 (also
integrated the brick's 3 upstream commits). I. **llms_verifier/llm-
verifier RED — Stream T DONE (5a3e036a)**. Root cause (§11.4.102):
NOT a CLI defect — a foreign TLS service occupies port 8080 on this
shared host (302 → https, cert invalid for localhost → x509), and the CLI
provably never speaks TLS (no `ListenAndServeTLS`). Test-side fix:
extended `serverUnavailable()` to recognize the x509/TLS condition as
the §11.4.3 no-compatible-server SKIP it already documents (no
assertion weakened). Submodule integrated 11 upstream commits +
FF-pushed; pointer → 8a184dab. Follow-up: these CLI tests SKIP here (no
compatible server on 8080) — a future §11.4.98 improvement could
spin up an ephemeral server to actually exercise the CLI. J. **gofmt
sweep — Stream J DONE / 5 of 7 landed (f7846319 + 5 brick**

commits). 291 files, gofmt-equivalence PROVEN
(gofmt(committed)==current byte-for-byte). **LANDED + FF-pushed:** ota-protocol 8afc07, challenges 32f6ef0, llms_verifier 02ac454d, security 96adc8b, containers 367d39d. **DEFERRED (pre-existing mirror fork — operator decision):** llm_orchestrator (github/upstream tip ee229a7 already gofmt-clean, origin a484f7d forked +1 — sweep is a no-op there) and vision_engine (origin b417a40 forked from github a97df79). Converging forked mirrors for whitespace is disproportionate risk; both restored to parent-pinned, nothing consumed changed. docs/research/submodule_gofmt_vet_sweep_20260710/FINDINGS.md Rev 2. http3 untouched (dirty foreign, §11.4.84). **K. Android bricks static-only** (ota-android-agent, ota-update-engine-bridge): no gradlew wrapper committed → full AGP build not run (needs Android SDK). Honest §11.4.6 boundary; a real build pass is owed when the toolchain is available.

Server §11.4.169 test-type gaps (from Stream V audit, docs/research/server_test_type_coverage_audit_20260709/AUDIT.md; suite is 100% PASS + 0 races today):

L. Memory + Fuzz gaps — DONE (f82a77e4) + review-hardened (1df9a649). Stream W added the heap-growth assertion + FuzzTokenSignerVerify. The whole-branch review (Important-1) found the memory test's per-batch-delta threshold blind to a STEADY leak + overclaiming; **rewritten to a retention-scales-with-load discriminator** (self-validated classifyHeapGrowth §11.4.107(10) + §11.4.115 RED on a real 4 KB/iter injected leak leak=true; healthy real router leak=false). docs/qa/20260710-memory-leak-discriminator-fix/EVIDENCE.md. **M2. Postgres integration suite — DONE, RAN e2e (720ef748).** Self-booting postgres:16-alpine via rootless podman (submodules/containers); 15/15 packages ok + -race clean; real pgx TCP-kill/SQLSTATE 23514/uq_fabric_lease_active fault evidence; teardown clean. docs/qa/20260709-server-postgres-integration/EVIDENCE.md. **N. Benchmark regression baseline — DONE (1df9a649, Stream N-sec).** Existing benchmarks captured -count=3 + new internal/api/token_bench_test.go isolating the crypto hot path (Mint 803 / Verify 1682 / VerifyReject 481 ns/op). docs/qa/20260710-server-security-and-benchmark-baseline/. **O. Security follow-ups — OPERATOR-GATED; decision brief READY (660e8e6d, Stream OB1).** Confirmed NO security-response-headers set today (chain: recovery → request-id → max-inflight → compression). Tiered header proposal (SPA-CSP deferred to avoid white-screening the UI) drafted un-wired in docs/research/operator_brief_security_headers_ddos_20260710/BRIEF.md. Operator decides which headers to enable. (V's positive finding stands: HMAC-SHA256, not multi-alg — no alg=none.) **P. Aborted security-suite**

run — DONE (1df9a649, Stream N-sec): re-ran the security subset PASS under -race + fuzz (115k execs, 0 crashes), fresh evidence captured. Cleared. Q. **DDoS default posture — OPERATOR-GATED; decision brief READY (660e8e6d, Stream OB1).** Confirmed HELIX_MAX_INFLIGHT defaults to 0=UNLIMITED today (flood → unbounded goroutines/memory → OOM). Proposal: conservative 256 default — a §11.4.122 behavior change (makes 0 an explicit unlimited opt-out) needing operator sign-off + .env.example/deploy-guide note. Same brief as O.

Prior (A/B path):

1. **OTA-003 — DONE (VERIFIED on nezha 2026-06-23).** Real Android A/B (update_engine apply → slot flip _a→_b → auto-rollback) proven on a live Cuttlefish cvd; evidence docs/qa/20260623-cuttlefish-tier2-ab/REPORT.md; §11.4.135 guard GREEN. Migrate the Issues.md entry → Fixed.md (conductor) and confirm exports.
 2. **OTA-004 — Hardware unblock.** When a physical RK3588 / Orange Pi 5 Max board becomes reachable over ADB/SSH, flash and validate Tier-3 (vendor HAL, U-Boot slot-switch, real-partition dm-verity). Boards stay control-plane-only by operator decision (§11.4.133) until then.
 3. **Feature-coverage video recording.** Produce §11.4.153 mandatory per-feature real-use videos confirming every server endpoint, every emulator tier, and every submodule works — with §11.4.159 window-scoped MP4 capture + §11.4.160 vision verification.
 4. **Standing regression-guard suite (§11.4.135).** Ensure every closed OTA-NNN item has its §11.4.115 polarity-switch regression test registered in the suite.
-

6. Binding constraints

- **Anti-bluff (§11.4 / §107):** Every PASS carries captured physical evidence per §11.4.5 / §11.4.69 / §11.4.107. Metadata-only / config-only / absence-of-error / grep-without-runtime PASS are all forbidden.
- **No-force-push (§11.4.113):** git push --force, --force-with-lease, +<ref> are STRICTLY FORBIDDEN. Always merge onto latest main and push fast-forward-only.
- **Commit via commit_all.sh:** All changes use the project's canonical commit wrapper. Direct git add/git commit/git push are never used.

- **Four-layer fix-verification (§11.4.108):** SOURCE → ARTIFACT → RUNTIME-ON-CLEAN-TARGET → USER-VISIBLE. Runtime signature is the definition of done.
 - **Independent review (§11.4.142 / §11.4.125):** Every change passes an independent code-review agent before build. Review iterates to zero-finding GO per §11.4.134.
 - **Multi-upstream push (§2.1):** Every commit fans out to all four upstreams (GitHub + GitLab + GitFlic + GitVerse).
 - **Rootless containers (§11.4.161):** All containerized workloads use Podman in rootless mode via vasic-digital/containers submodule.
 - **No remote CI (§11.4.156):** All CI/CD automation is DISABLED. Enforcement is through local git hooks + `pre_build_verification.sh`.
-

7. Feature tracking

Feature inventory and per-row status: `docs/features/Status.md` (Rev 18, 2026-06-22). Summary companion: `docs/features/Status_Summary.md`.

8. Fresh session start

```
git fetch --all --prune --tags
```

Then read this file (`docs/CONTINUATION.md`) and `docs/Issues.md` for the full active-item context. **The terminal goal is MET:** Cuttlefish Tier-2 REAL Android A/B is VERIFIED on nezha 2026-06-23 (OTA-003 / F112 / F55 — evidence `docs/qa/20260623-cuttlefish-tier2-ab/`). The remaining open item is OTA-004 (Tier-3 physical RK3588), which is operator-blocked on hardware (boards stay control-plane-only by operator decision, §11.4.133). The cvd is left running on nezha.